

| O S I N T R E S E A R C H



Manuale Operativo di OSINT *e Investigazione Digitale*

Guida pratica a strumenti, tecniche e metodologie
per l'intelligence da fonti aperte

Crediti e Licenza

AUTORE

Sebastiano Caio

DATA

Agosto 2026

VERSIONE

Prima edizione — aggiornata ad agosto 2026

© 2026 Sebastiano Caio. Tutti i diritti riservati salvo quanto concesso dalla licenza sottostante.

Quest'opera è distribuita con licenza Creative Commons Attribuzione — Non Commerciale — Non Opere Derivate 4.0 Internazionale (CC BY-NC-ND 4.0). È consentito copiare e ridistribuire il presente manuale, in qualsiasi formato, alle seguenti condizioni: attribuzione della paternità dell'opera all'autore; esclusivamente per finalità non commerciali; senza apportare modifiche, tagli o rielaborazioni al contenuto. Testo completo della licenza: creativecommons.org/licenses/by-nc-nd/4.0

Questo manuale è una raccolta personale di studio, condivisa a scopo didattico. Gli strumenti e le tecniche descritti sono destinati a un uso legale ed etico, così come specificato nella Nota su uso etico e legale in Introduzione. L'autore non si assume responsabilità per un uso improprio dei contenuti da parte di terzi.

§ Indice

INTRODUZIONE

- 01 FONDAMENTI TEORICI
 - 02 INTRODUZIONE ALLE INDAGINI DIGITALI
 - 03 CATEGORIE DELL'OSINT
 - 04 PROCESSO OPERATIVO OSINT
 - 05 ESEMPI PRATICI DI CORRELAZIONE (PIVOTING)
 - 06 CLEAR WEB, DEEP WEB E DARK WEB
 - 07 SITI WEB, DOMINI, IP, DNS E CERTIFICATI SSL
 - 08 STORICO PAGINE WEB E ARCHIVIAZIONE
 - 09 EMAIL — ANALISI, HEADER E OSINT
 - 10 NUMERI DI TELEFONO
 - 11 USERNAME E PRESENZA SOCIAL
 - 12 SOCIAL NETWORK PER PIATTAFORMA
 - 13 IMMAGINI, METADATI E GEOSINT
 - 14 ANONIMATO SUL WEB
 - 15 VEICOLI E TARGHE
 - 16 STRUMENTI DI PAGAMENTO (IBAN E CARTE)
 - 17 ALTRI SERVIZI PUBBLICI ITALIANI
 - 18 DATA BREACH E DATI TRAPELATI (LEAKS)
 - 19 CRIPTOVALUTE
 - 20 DARK WEB
 - 21 TRACKING AEREI
 - 22 MARCHI E PROPRIETÀ INTELLETTUALE
 - 23 VERIFICA DI FOTO/VIDEO FALSI E BANCONOTE CONTRAFFATTE
 - 24 PROVA DIGITALE E FORENSICS
 - 25 SEGNALAZIONE SITI TRUFFA
 - 26 FRAMEWORK OSINT GENERICI (MULTI-FUNZIONE)
 - 27 TOOLKIT KALI LINUX — RIEPILOGO PER CATEGORIA
 - 28 SOFTWARE DI SUPPORTO E PRODUTTIVITÀ
 - 29 GOOGLE DORKING
 - 30 RICERCA DI ENDPOINT E API DIMENTICATI
 - 31 RICERCA DI DISPOSITIVI CONNESSI A INTERNET
 - 32 CASI STUDIO
-

INTRODUZIONE

Questo manuale nasce come una raccolta personale delle conoscenze, delle esperienze e degli apprendimenti maturati nel corso del tempo, con l'obiettivo di condividerli con chi desidera avvicinarsi al mondo dell'OSINT.

Le valutazioni, le analisi e i suggerimenti presenti nelle pagine che seguono non devono essere interpretati come verità assolute o indicazioni definitive, ma come considerazioni personali basate sull'esperienza diretta, sulla sperimentazione e sull'analisi pratica degli strumenti descritti. Ogni lettore potrà quindi valutare autonomamente le diverse soluzioni disponibili e individuare quelle più adatte alle proprie necessità, obiettivi e contesto operativo.

Il panorama degli strumenti OSINT è estremamente vasto e in continua crescita. La selezione proposta in questo manuale non ha la pretesa di rappresentare un catalogo completo, ma raccoglie strumenti scelti sulla base dell'esperienza personale e della loro efficacia dimostrata nell'utilizzo concreto.

L'OSINT è una disciplina dinamica, caratterizzata da una continua evoluzione di strumenti, tecniche e servizi. Per questo motivo, nessun manuale può considerarsi realmente definitivo o completo. Al di là della conoscenza dei singoli strumenti, l'elemento fondamentale è sviluppare un metodo di lavoro strutturato, mantenere un approccio curioso e analitico e coltivare un costante aggiornamento delle proprie competenze.

Questo manuale è aggiornato ad agosto 2026. Considerata la rapidità con cui cambiano strumenti e servizi in ambito OSINT, alcuni contenuti potrebbero non essere più attuali al momento della lettura.

Per ciascuno strumento viene inoltre indicata la relativa tipologia — ad esempio sito web, tool da riga di comando per Linux/Kali Linux, software desktop, applicazione mobile, estensione del browser o altra soluzione — così da fornire immediatamente un'indicazione sulle modalità di utilizzo e sul contesto operativo in cui può essere impiegato.

OSINT passivo e OSINT attivo

Prima di entrare nel merito degli strumenti, è utile chiarire una distinzione di base:

- **OSINT passivo:** consiste nel raccogliere informazioni già pubblicamente disponibili, senza interagire direttamente con il soggetto o il sistema oggetto della ricerca (es. consultare un profilo social pubblico, un archivio, un database aperto). Non lascia tracce rilevabili dalla parte osservata.
- **OSINT attivo:** prevede un'interazione diretta, seppur minima, con il soggetto o il sistema in esame (es. una richiesta di connessione, una query che genera una risposta osservabile, un'interazione che potrebbe essere notata dall'altra parte). Può lasciare tracce ed è generalmente da valutare con più attenzione, anche sul piano legale, a seconda del contesto.

Un consiglio su Linux e Kali Linux

Gran parte degli strumenti da riga di comando presentati in questo manuale non sono legati esclusivamente a Kali Linux: nella maggior parte dei casi possono essere installati anche su altre distribuzioni Linux, purché siano soddisfatte le dipendenze richieste da ciascun tool. Per ogni strumento, in caso di dubbi sull'installazione, è quasi sempre possibile trovare online guide e tutorial dettagliati (spesso in lingua inglese) che mostrano passo passo come procedere.

Detto questo, la distro che consiglio personalmente per lavorare in ambito OSINT — e più in generale sicurezza informatica — resta **Kali Linux**, perché:

- include centinaia di strumenti preinstallati per raccolta e analisi di informazioni (DNS, WHOIS, metadati, social media, web intelligence);
- è ottimizzata per la sicurezza informatica, con aggiornamenti frequenti e ampio supporto a nuovi tool;
- è molto personalizzabile, permettendo di installare rapidamente software aggiuntivo per esigenze specifiche;
- ha una vasta comunità e documentazione, che rende più semplice imparare a usare gli strumenti disponibili;
- supporta ambienti live, virtuali e installazioni dedicate, adattandosi a diversi contesti di lavoro.

È inoltre la distro che consiglio a chi, oltre all'OSINT, vuole in futuro approfondire il mondo del penetration testing.

Nota sull'uso etico e legale

Gli strumenti e le tecniche descritti in questo manuale sono destinati esclusivamente a scopi didattici, di studio personale e di ricerca legittima, quali la verifica di informazioni pubbliche, la sicurezza informatica, il giornalismo investigativo, il contrasto alle frodi e l'analisi della disinformazione.

L'utilizzo di qualsiasi strumento o tecnica illustrati nel presente manuale è sotto la piena responsabilità dell'utilizzatore, che è tenuto a rispettare le leggi vigenti nella propria giurisdizione, la normativa in materia di protezione dei dati personali (in Italia e nell'Unione Europea, il Regolamento (UE) 2016/679 – GDPR) e i Termini di Servizio delle piattaforme coinvolte.

In particolare:

- **La raccolta sistematica di dati da siti web o servizi online, anche quando tecnicamente possibile, può violare i Termini di Servizio della piattaforma interessata e, in alcuni casi, la normativa applicabile.**
- **Le tecniche descritte non devono essere utilizzate per attività di stalking, molestie, discriminazione, violazione della privacy o qualsiasi altra condotta illecita o lesiva dei diritti altrui.**
- **Alcuni strumenti possono richiedere autorizzazioni specifiche oppure essere soggetti a limitazioni normative che variano in base al contesto d'uso e alla giurisdizione. In caso di dubbio, è opportuno richiedere una consulenza legale qualificata prima del loro impiego. L'autore del manuale non incoraggia né promuove l'utilizzo degli strumenti descritti per finalità illecite o contrarie ai principi etici dell'OSINT. Il lettore è responsabile del rispetto della normativa applicabile e delle conseguenze derivanti dall'uso delle informazioni e delle tecniche illustrate.**

Cos'è l'OSINT

OSINT (Open Source Intelligence) è la disciplina che raccoglie, analizza e correla informazioni provenienti da fonti pubblicamente accessibili — siti web, social network, registri pubblici, documenti, immagini, dati tecnici di rete — per produrre conoscenza utile a un obiettivo investigativo, di sicurezza o di verifica.

È uno strumento efficiente nelle attività investigative per alcuni motivi concreti:

- **Costo contenuto:** la maggior parte delle fonti è gratuita o a basso costo, a differenza di altre discipline di intelligence che richiedono accesso a sistemi riservati o sorveglianza attiva.
- **Basso rischio operativo:** non richiede interazione diretta con il soggetto della ricerca nella maggior parte dei casi (vedi OSINT passivo, sezione successiva).
- **Ampiezza delle fonti:** la quantità di dati pubblicamente disponibili oggi (social, dati aziendali, tracce digitali) è enormemente più ampia rispetto al passato, e in costante crescita.
- **Verificabilità:** le informazioni raccolte da fonti aperte sono spesso tracciabili e ripercorribili, un vantaggio importante quando serve dimostrare come si è arrivati a una conclusione.

Il concetto di Intelligence

Nel contesto investigativo, per **Intelligence** si intende il processo di trasformazione di dati grezzi in informazioni utili e strutturate, attraverso raccolta, analisi, correlazione e valutazione. Un singolo dato isolato (un numero di telefono, un indirizzo email) ha poco valore da solo: diventa intelligence quando viene collegato ad altri dati, contestualizzato e valutato per la sua affidabilità. L'OSINT è una delle discipline che compongono l'intelligence nel suo complesso, insieme ad altre che vedremo più avanti (sezione "Categorie dell'OSINT").

Utilizzo legale ed etico dell'OSINT

L'OSINT lavora su informazioni pubblicamente accessibili, ma "pubblicamente accessibile" non equivale automaticamente a "liberamente utilizzabile per qualsiasi scopo". Alcuni principi guida: - La liceità di una ricerca dipende non solo dalla fonte del dato, ma anche dalle **modalità di raccolta** e dalla **finalità d'uso**. - Normative come il GDPR (in ambito europeo) regolano il trattamento dei dati personali anche quando questi sono già pubblici: raccogliere sistematicamente e conservare dati su una persona può configurare un trattamento soggetto a obblighi specifici. - Un uso etico dell'OSINT implica proporzionalità (raccolgere solo ciò che serve all'obiettivo dichiarato), minimizzazione dei dati e attenzione a non ledere diritti di terzi. - Contesti professionali diversi (forze dell'ordine, giornalismo investigativo, sicurezza aziendale, ricerca accademica) hanno cornici normative e deontologiche differenti: le stesse tecniche possono essere lecite in un contesto e problematiche in un altro.

Footprinting e Passive Footprinting

Il **footprinting** è la fase di raccolta preliminare di informazioni su un obiettivo (una persona, un'azienda, un'infrastruttura), finalizzata a costruire una mappa iniziale prima di un'analisi più approfondita. Si distingue in due modalità:

- **Footprinting attivo:** comporta un'interazione diretta con il sistema o la persona in esame (es. una scansione di rete, una richiesta HTTP mirata), che può essere rilevata dalla controparte.
- **Passive footprinting:** raccoglie informazioni senza alcuna interazione diretta con l'obiettivo, affidandosi esclusivamente a fonti terze già pubbliche (motori di ricerca, archivi, social network, database aperti). È la modalità coerente con la maggior parte delle tecniche OSINT descritte in questo manuale, proprio perché non lascia tracce rilevabili dalla parte osservata.

Fonti aperte (Open Sources) e fonti chiuse (Closed Sources)

- **Fonti aperte (Open Sources):** informazioni accessibili senza restrizioni particolari, spesso gratuitamente, da chiunque — siti web pubblici, social media, registri pubblici, dati governativi aperti, media.
- **Fonti chiuse (Closed Sources):** informazioni protette da restrizioni di accesso, riservate a soggetti autorizzati — database aziendali interni, sistemi riservati alle forze dell'ordine, archivi coperti da segreto istruttorio o industriale.

L'OSINT lavora per definizione sulle fonti aperte. Il confine tra le due categorie non è sempre netto: un dato può essere formalmente pubblico ma di fatto difficile da reperire (dispersione informativa), oppure tecnicamente accessibile per un errore di configurazione pur non essendo stato pensato per la pubblicazione (vedi Google Dorking, sezione dedicata più avanti).

Domicilio elettronico

Il **domicilio elettronico** è l'indirizzo digitale (tipicamente una casella di posta elettronica certificata, PEC, in ambito italiano) presso il quale una persona fisica o giuridica può ricevere comunicazioni con valore legale, in alternativa o in aggiunta al domicilio fisico tradizionale. Il concetto è rilevante in ambito OSINT/investigativo perché un domicilio elettronico verificato può fornire un punto di contatto ufficiale e giuridicamente qualificato per una persona o un'azienda (vedi anche INI-PEC, sezione Registri Imprese).

Dati pubblici e dati privati

- **Dati pubblici:** informazioni che un soggetto ha reso accessibili a chiunque, consapevolmente o per effetto di un obbligo normativo (es. una visura camerale, un post pubblico su un social network, un dato pubblicato su un registro ufficiale).
- **Dati privati:** informazioni riservate, la cui divulgazione non è stata autorizzata dal soggetto interessato e il cui accesso non autorizzato può configurare una violazione di legge (es. il contenuto di una casella email privata, dati sanitari, comunicazioni private).

La distinzione non dipende solo dalla tecnica usata per ottenere il dato, ma dalla natura del dato stesso e dal contesto in cui è stato reso disponibile: un dato "trapelato" da un data breach resta un dato privato nella sua natura, anche se tecnicamente reperibile online (vedi sezione Data Breach per gli aspetti legali specifici).

02 INTRODUZIONE ALLE INDAGINI DIGITALI

Le **indagini digitali (Digital Investigations)** sono l'insieme di attività volte a raccogliere prove informatiche a supporto di un procedimento, un accertamento o una verifica. Alcuni punti chiave:

- Vengono svolte per **raccogliere prove informatiche** rilevanti rispetto a un fatto da accertare.
- Possono essere utilizzate sia in **ambito penale** (reati informatici, frodi, diffamazione online, ecc.) sia in **ambito civile** (controversie contrattuali, dispute societarie, verifiche patrimoniali).
- Sono fondamentali in seguito a **incidenti informatici, frodi, violazioni di sistemi, dispute aziendali** e altri illeciti in cui una componente digitale è coinvolta come prova o come mezzo.
- L'obiettivo principale non è semplicemente "trovare" un'informazione, ma **acquisire, preservare e analizzare prove digitali in modo corretto e utilizzabile** — cioè con modalità che ne garantiscano l'integrità e la validità in un eventuale contesto formale (giudiziario o arbitrale).

Questo manuale non è un trattato di Digital Forensics (la disciplina tecnica che si occupa nel dettaglio dell'acquisizione forense di dispositivi, memorie e supporti), ma alcune tecniche presentate — in particolare hashing, timestamping e acquisizione forense di pagine web (sezioni dedicate più avanti) — condividono con la Digital Forensics il principio fondamentale della **catena di custodia**: ogni prova digitale, per avere valore, deve poter dimostrare di non essere stata alterata dal momento della raccolta in poi.

03 CATEGORIE DELL'OSINT

L'intelligence da fonti aperte non è un blocco unico: si articola in diverse discipline specialistiche, ciascuna focalizzata su un tipo di fonte o di dato. Conoscerle aiuta a orientarsi tra gli strumenti e a capire in quale "famiglia" rientra una determinata tecnica. Ecco una panoramica delle principali:

- **SOCMINT** (Social Media Intelligence): raccolta e analisi di informazioni dai social network.
- **GEOINT** (Geospatial Intelligence): analisi di dati geografici e geolocalizzati, spesso da immagini satellitari o mappe.
- **IMINT** (Imagery Intelligence): raccolta di informazioni da immagini e materiale fotografico.
- **SIGINT** (Signals Intelligence): intelligence ottenuta dall'intercettazione di segnali elettronici o di comunicazione (dominio tipicamente militare/governativo).
- **MASINT** (Measurement and Signature Intelligence): intelligence basata su misurazioni tecniche e "firme" caratteristiche di oggetti o fenomeni (es. emissioni, tracce fisiche).
- **TECHINT** (Technical Intelligence): raccolta di informazioni su tecnologie, sistemi e capacità tecniche.
- **FININT** (Financial Intelligence): analisi di dati e flussi finanziari, utile ad esempio nel tracciamento di transazioni sospette (vedi anche sezione Criptovalute).
- **HUMINT** (Human Intelligence): informazioni raccolte tramite il contatto diretto con persone (interviste, fonti umane) — è la disciplina più antica di intelligence, distinta dall'OSINT perché non si basa su fonti aperte ma su interazione diretta.
- **OPSEC** (Operations Security): non è propriamente una disciplina di raccolta, ma l'insieme di pratiche difensive per proteggere le proprie informazioni sensibili da essere raccolte da altri (vedi anche sezione Anonimato sul Web).
- **TSCM** (Technical Surveillance Counter-Measures): tecniche di individuazione e contrasto di dispositivi di sorveglianza tecnica (es. microspie, intercettazioni ambientali).
- **Counter Intelligence (CI)**: attività volta a contrastare le attività di intelligence condotte da terzi nei propri confronti.

04 PROCESSO OPERATIVO OSINT

Non esiste un workflow universale dell'OSINT. Ogni ricerca dipende dall'obiettivo, dal contesto e dalle informazioni disponibili al momento: un punto di partenza (un'email, un nome, un dominio) può richiedere un percorso completamente diverso da un altro. Lo scenario cyber è inoltre estremamente dinamico — nuovi strumenti, nuove piattaforme e nuove restrizioni compaiono di continuo — e questo richiede spesso di adattare in corsa il proprio metodo di lavoro, più che seguire una procedura fissa.

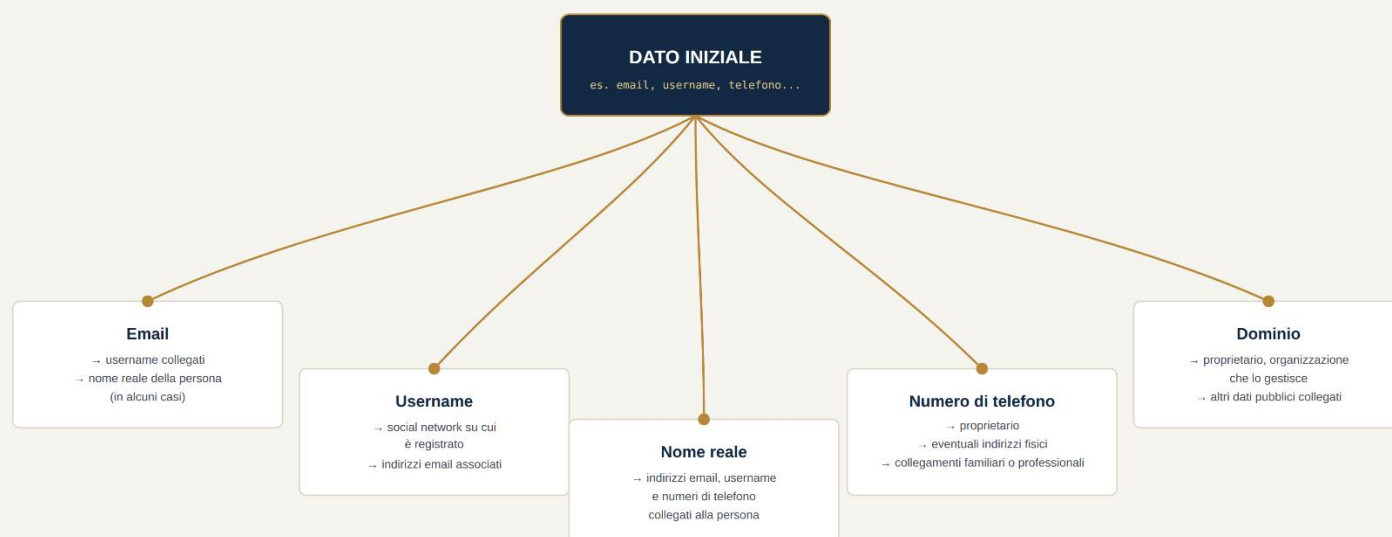
Detto questo, è utile avere una linea guida generica di riferimento, da adattare caso per caso — **non uno standard assoluto**, ma un possibile ordine ragionevole in cui muoversi:

1. **Raccolta delle informazioni iniziali:** definire cosa si sa già e cosa si sta cercando.
2. **Utilizzo dei motori di ricerca:** prima ricognizione generale sul soggetto o argomento.
3. **Google Dorks e query avanzate** su altri motori di ricerca (Yandex, Bing, ecc.) per far emergere contenuti non immediatamente visibili (vedi sezione dedicata).
4. **Utilizzo di strumenti OSINT specifici**, in base al tipo di dato di partenza (email, username, telefono, dominio — vedi le sezioni pratiche del manuale).
5. **Analisi dei social network** collegati al soggetto o all'organizzazione.
6. **Ricerca su forum e community** pertinenti al contesto dell'indagine.
7. **Ricerca nei Data Breach**, per verificare eventuali esposizioni pregresse (vedi sezione dedicata, incluse le implicazioni legali).
8. **Analisi del Dark Web**, quando legalmente consentito e pertinente al caso (vedi sezione dedicata).
9. **Correlazione delle informazioni raccolte:** mettere in relazione i dati ottenuti nei passaggi precedenti, cercando collegamenti (vedi anche "Esempi pratici di correlazione" più avanti).
10. **Verifica e validazione delle fonti:** prima di considerare un'informazione affidabile, verificarne la provenienza e, se possibile, riscontrarla con altre fonti indipendenti.

Questo schema è pensato come punto di partenza per chi si avvicina all'OSINT, non come sequenza rigida da seguire meccanicamente: con l'esperienza, ogni professionista tende a sviluppare un proprio metodo, spesso non lineare, in base al tipo di ricerche che svolge più frequentemente.

Il principio del Pivoting

UN SINGOLO DATO COME PUNTO DI PARTENZA PER SCOPRIRE ALTRI



Ogni nuovo dato trovato va valutato come possibile ponte verso altre informazioni, fino a costruire un quadro sufficientemente completo — sempre verificando, ad ogni passaggio, l'affidabilità della fonte prima di darla per assodata.

Uno dei principi più importanti dell'OSINT è che **ogni informazione può diventare il punto di partenza per ottenerne altre** — questa tecnica si chiama comunemente **pivoting**: si parte da un dato noto e lo si usa come “perno” per scoprire dati collegati, che a loro volta possono aprire nuove direzioni di ricerca.

Alcuni esempi pratici di come un singolo dato può espandersi:

- **Da un indirizzo email** → si possono individuare eventuali username collegati e, in alcuni casi, il nome reale della persona (vedi sezione Email ed Email — Analisi, Header e OSINT).
- **Da uno username** → si possono individuare i social network su cui è registrato e, di riflesso, possibili indirizzi email associati agli stessi account (vedi sezione Username e Presenza Social).
- **Da un nome reale** → si possono ricercare indirizzi email, username e numeri di telefono collegati alla persona (vedi le sezioni dedicate a Email, Username e Numeri di Telefono).
- **Da un numero di telefono** → si può risalire al proprietario, a eventuali indirizzi fisici e a possibili collegamenti familiari o professionali (vedi sezione Numeri di Telefono).
- **Da un dominio** → si può risalire al proprietario, all'organizzazione che lo gestisce o ad altri dati pubblicamente disponibili collegati (vedi sezione Siti Web, Domini, IP, DNS e Certificati SSL).

Il valore del pivoting sta proprio nel fatto che raramente un'indagine OSINT si esaurisce con un solo strumento o una sola ricerca: ogni nuovo dato trovato va valutato come possibile ponte verso altre informazioni, fino a costruire un quadro sufficientemente completo — sempre verificando, ad ogni passaggio, l'affidabilità della fonte prima di darla per assodata (vedi punto 10 del Processo Operativo OSINT).

Prima di addentrarsi nelle tecniche pratiche, è utile chiarire il rapporto tra le tre “porzioni” di internet che si incontrano più spesso in ambito OSINT:

- **Clear Web** (o surface web): la parte di internet indicizzata dai normali motori di ricerca (Google, Bing, ecc.) e liberamente consultabile senza strumenti particolari. È quella con cui la maggior parte delle persone interagisce quotidianamente.
- **Deep Web**: tutto ciò che non è indicizzato dai motori di ricerca tradizionali, ma che non è necessariamente nascosto o illegale — rientrano qui, ad esempio, contenuti dietro login (webmail, area riservata di un conto bancario), database aziendali, contenuti dinamici generati su richiesta, pagine intranet. È di gran lunga la porzione più estesa del web.
- **Dark Web**: una sottoporzione ancora più ridotta, accessibile solo tramite reti e software dedicati (come Tor — vedi sezione Dark Web), pensata per garantire anonimato a chi naviga e a chi ospita i contenuti.

Un dato spesso citato è che i motori di ricerca indicizzerebbero solo una piccola parte del web complessivo — comunemente stimata tra il **4% e il 10%** del totale. È importante trattare questo numero per quello che è: **una stima generalmente accettata nella comunità, non un valore misurato in modo definitivo e assoluto** — la dimensione reale del Deep Web non è calcolabile con precisione, proprio per la sua natura non indicizzata.

Ciò che conta operativamente è il concetto che ne deriva: il Clear Web rappresenta solo una frazione limitata del contenuto disponibile online, la maggior parte delle informazioni digitali risiede nel Deep Web (in gran parte dati legittimi e non “nascosti” in senso investigativo, semplicemente non indicizzati), e il Dark Web è una porzione ulteriore, ancora più piccola, con caratteristiche e strumenti di accesso propri (approfonditi nella sezione dedicata).

Concetti di base

- **Dominio:** indirizzo alfabeticamente univoco di un sito web, composto da un nome e un'estensione, collegato tramite DNS a un indirizzo IP.
- **DNS (Domain Name System):** sistema che traduce i nomi a dominio in indirizzi IP, permettendo al browser di raggiungere i siti.
- **WHOIS:** protocollo che, interrogando database dedicati, permette di scoprire a quale provider appartiene un IP o un dominio.
- **Certificati SSL e sottodomini:** ogni certificato SSL emesso per un dominio viene registrato pubblicamente in log consultabili (Certificate Transparency Log, es. su crt.sh). Questo è utile in un'analisi preliminare perché spesso, quando viene emesso un certificato, compaiono insieme anche i sottodomini associati — anche quelli non collegati da nessun link visibile sul sito principale (es. staging.azienda.it, admin.azienda.it, test.azienda.it). Questi sottodomini "nascosti" possono rivelare ambienti di test, pannelli di amministrazione o servizi interni che l'organizzazione non intendeva rendere facilmente scopribili.
- **Metadati di un sito web:** oltre ai metadati EXIF delle immagini (vedi sezione 7), anche le pagine web contengono metadati incorporati nel codice HTML — ad esempio il nome del software usato per generarle (CMS), l'autore o la data di creazione/modifica. Questi dati aiutano a capire con quale tecnologia è stato costruito un sito e, in alcuni casi, possono rivelare informazioni che il proprietario non intendeva rendere visibili.

Procedura pratica: indagine completa su un sito web

1. Analizzare il sito con **WhatWeb** per scoprire tecnologie utilizzate e indirizzo IP.
2. Inserire l'IP ottenuto su un tool di geolocalizzazione (es. WhatIsMyIP).
3. Verificare l'IP su AbuseIPDB e Cisco Talos per la reputazione.
4. Controllare certificati SSL (VirusTotal, crt.sh) e sottodomini.
5. Visualizzare il codice sorgente della pagina (tasto destro → "Visualizza sorgente pagina") e cercare tag come <meta name="generator">, che spesso rivelano il CMS utilizzato; per i documenti scaricabili dal sito (PDF, DOCX, immagini), analizzarli separatamente con ExifTool (vedi sezione 7).
6. Eseguire Reverse IP, WHOIS e verificare lo storico del dominio.
7. Consultare la Wayback Machine per vedere le versioni storiche del sito: utile per capire come è cambiato nel tempo, individuare contenuti oggi rimossi ma un tempo pubblici, o recuperare vecchie versioni del codice sorgente (vedi anche sezione 2 — Storico Pagine Web e Archiviazione).
8. Se utile, usare un'AI per interpretare i dati raccolti.

Da fonti aperte, con un'indagine OSINT su un sito web è possibile ricavare complessivamente:

- Proprietario e dominio (WHOIS storico, registrazioni)
- Hosting, IP, DNS e infrastruttura
- Tecnologie usate (CMS, server, framework)
- Certificati SSL e sottodomini
- Contatti pubblici (email, telefoni)
- Metadati e contenuti nascosti o archiviati
- Collegamenti con altri siti, aziende o persone
- Presenza su social e tracce pubbliche correlate

1.1 Analisi IP

IP2Location	Sito web consultabile	Geolocalizzazione di un indirizzo IP (paese, città, provider).
WhatIsMyIP	Sito web consultabile	Mostra il proprio IP pubblico o permette di ottenere informazioni su un IP specifico.
MaxMind	Sito web consultabile	Servizio di geolocalizzazione IP professionale, usato anche in ambito enterprise.
IPinfo	Sito web consultabile	Dati su IP: geolocalizzazione, ASN, provider.
Ipstack	Sito web consultabile	API/servizio di geolocalizzazione IP.
centralops.net	Sito web consultabile	Suite di tool online per WHOIS, DNS, traceroute e ricognizione di rete.
urlscan.io	Sito web consultabile	Analizza un URL/sito e ne mostra comportamento, richieste di rete, IP coinvolti e screenshot.
nslookup.io	Sito web consultabile	Interrogazione DNS online (equivalente web del comando nslookup).
coordinate-gps.it	Sito web consultabile	Inserendo coordinate GPS, mostra il punto esatto sulla mappa.

1.2 Verifica reputazione e affidabilità IP

AbuseIPDB	Sito web consultabile	Database di segnalazioni di abuso; mostra se un IP è stato riportato per attività malevole e il relativo punteggio di affidabilità.
Cisco Talos Intelligence	Sito web consultabile	Reputazione, categoria e geolocalizzazione di un IP/dominio, basata su threat intelligence Cisco.
RIPE Database	Sito web consultabile	Database ufficiale europeo per l'assegnazione di blocchi IP; mostra a chi è allocato un range.
Whois Lookup	Sito web consultabile	Dati di registrazione di un dominio o IP (proprietario, registrar, date).
DomainTools (Whois)	Sito web consultabile	WHOIS avanzato e storico dei domini.

1.3 Rilevazione VPN / Proxy

ipqualityscore.com	Sito web consultabile	Rileva se un IP è associato a VPN, proxy o bot, con punteggio di rischio.
vpnapi.io	Sito web consultabile	API dedicata al controllo dell'uso di VPN su un IP.
abuseipdb.com	Sito web consultabile	Usato anche per verificare segnalazioni relative a IP proxy/VPN.

1.4 Verifica rete Tor

ExoneraTor	Sito web consultabile	Verifica se un determinato IP, in una certa data, era un nodo della rete Tor.
Tor Relay Search	Sito web consultabile	Ricerca tra i relay Tor attivi; filtrabile per paese (es. country:it) per verificare se un IP italiano compare tra i nodi Tor di quel paese. Metodo valido per qualsiasi nazione.

1.5 Certificati SSL

VirusTotal	Sito web consultabile	Il migliore per analisi combinata di siti, certificati SSL e reputazione dei domini/IP.
crt.sh	Sito web consultabile	Motore di ricerca sui certificati SSL emessi (Certificate Transparency Log), utile anche per scoprire sottodomini.
cert-cli	Tool utilizzabile su Kali Linux	Versione da terminale per interrogare e analizzare certificati SSL.

1.6 Scoperta sottodomini e raccolta dati su dominio

Knock	Tool utilizzabile su Kali Linux	Enumera i sottodomini di un dominio in esame.
theHarvester	Tool utilizzabile su Kali Linux	Raccoglie email, host, sottodomini e indirizzi IP collegati a un dominio da fonti pubbliche.

1.7 Analisi domini .IT

Registro.it	Sito web consultabile	Registro ufficiale dei domini con estensione .it; permette WHOIS e verifiche di registrazione.
--------------------	-----------------------	--

Concetti di base

- Gli archivi web mantengono "fotografie" storiche di un sito in date diverse, permettendo di vedere com'era una pagina in passato anche se nel frattempo è stata modificata o rimossa.
- Oltre alla semplice consultazione visiva, la Wayback Machine è anche un vero strumento OSINT: le versioni storiche di un sito possono contenere informazioni che nella versione attuale non sono più presenti o accessibili.
- Per rendere probatoria un'acquisizione web (cioè utilizzabile come prova documentale), è consigliabile acquisire la pagina con strumenti di web forensic dedicati, non con un semplice screenshot.

Procedura pratica: uso OSINT del Wayback Machine

Le versioni storiche archiviate di un sito possono essere sfruttate per:

- **Analizzare il codice sorgente di vecchie versioni** del sito, che può contenere commenti, percorsi di file o riferimenti non più presenti nella versione attuale.
- **Verificare eventuali metadati ancora presenti** in pagine o documenti archiviati (vedi anche sezione 1 e sezione 7).
- **Osservare come il sito è cambiato nel tempo**, utile per capire l'evoluzione di un'azienda, di un progetto o di un'organizzazione.
- **Individuare informazioni oggi rimosse ma un tempo pubbliche**: pagine cancellate, annunci, contenuti sostituiti o "nascosti" successivamente, che restano comunque consultabili nello snapshot storico.

Procedura pratica: acquisizione con valore probatorio

1. Verificare lo storico di una pagina su Wayback Machine (Archive.org) o CachedView.
2. Se serve un'acquisizione con valore probatorio, usare uno strumento di web forensic dedicato (vedi sotto) per congelare la pagina con garanzie di integrità.

Strumenti

Wayback Machine (Archive.org)	Sito web consultabile	Il principale archivio storico di pagine web; permette di vedere come appariva un sito in una data passata e di analizzarne le versioni precedenti a fini OSINT.
CachedView	Sito web consultabile	Servizio alternativo per consultare versioni cache di pagine web.
Web Forensic Instant	Sito - App mobile	Acquisizione forense di pagine web con garanzie di integrità, per uso probatorio.
Project FIT (GitHub, release v2.0)	Tool utilizzabile su Kali Linux/GitHub	Strumento per il congelamento di pagine web e screen recording a fini di acquisizione forense.

Concetti di base

- Ogni email, oltre al testo visibile, contiene un **header** (l'intestazione tecnica del messaggio) con informazioni sui server di transito e sui protocolli di autenticazione (SPF, DKIM, DMARC).
- L'indirizzo IP del mittente si trova nelle righe **Received**: all'interno dell'header dell'email.
- Se l'email è stata inviata tramite un provider come Gmail o Outlook.com, l'header normalmente mostra gli IP dei server del provider, non l'IP pubblico del dispositivo del mittente. Per ottenere l'eventuale IP di origine conservato nei log del provider è in genere necessario un procedimento legale (ad esempio una richiesta dell'autorità competente), non una semplice attività OSINT.

Procedura pratica: come trovare l'header e individuare l'IP di provenienza (video tutorial: youtu.be/UBNQw3X9EXw)

Su Gmail:

1. Apri la mail da PC.
2. Clicca sui tre puntini in alto a destra del messaggio.
3. Seleziona "Mostra originale".
4. Nell'header, individua le righe **Received**: e leggi l'IP indicato.

Su altri servizi (Outlook, ecc.):

1. Apri la mail.
2. Cerca un'opzione simile a "Mostra originale" o "Visualizza sorgente messaggio".
3. Individua allo stesso modo le righe **Received**.

Se non si riesce a individuare l'IP manualmente:

1. Copia l'intero header della mail.
2. Vai su mxtoolbox.com/Public (sezione Analyze Header).
3. Incolla l'header: il sito mostra automaticamente le informazioni principali e gli IP rilevanti.

Procedura generale di ricerca OSINT su un indirizzo email:

1. Usare tool OSINT dedicati per verificare a quali servizi è registrata l'email (vedi tabella sotto).
2. Se risulta collegata a un profilo Facebook o altro social, approfondire quel profilo.
3. Cercare nome/cognome associato, filtrando per città ed età se sono già noti.
4. Da un'email possono emergere nuovi numeri di telefono, profili social e altri dati collegabili tra loro.

Strumenti

Holehe	Tool utilizzabile su Kali Linux	Verifica su quali servizi online (social, piattaforme, ecc.) è registrato un indirizzo email.
GHunt	Tool utilizzabile su Kali Linux	Ricerche su account Google: recupera informazioni pubbliche associate a un'email Gmail, incluse eventuali recensioni Google lasciate dall'utente e dove sono visibili.
mxtoolbox.com	Sito web consultabile	Analisi header email: estrae IP, informazioni SPF/DKIM/DMARC e dati di instradamento.
Have I Been Pwned	Sito web consultabile	Verifica se un'email è comparsa in data breach noti.
IntelligenceX	Sito web consultabile (richiede registrazione)	Motore di ricerca OSINT su leak e data breach; spesso restituisce più informazioni rispetto ad altri servizi simili.

Truffe via email e frodi sul cambio IBAN (Business Email Compromise)

Concetti di base

Una delle truffe più diffuse ai danni di aziende è la **Business Email Compromise (BEC)**: un truffatore si finge un fornitore, un cliente o un dirigente già conosciuto dalla vittima, tramite un'email che a un primo sguardo sembra identica a quella originale, ma nasconde piccole differenze. Lo scopo tipico è farsi comunicare un IBAN diverso da quello reale su cui dirottare un pagamento già previsto tra le due aziende.

Le tecniche più comuni usate dai truffatori sono:

- **Dominio simile (typosquatting)**: si registra un dominio quasi identico a quello dell'azienda reale, cambiando una lettera o aggiungendo un trattino (es. azienda-spa.com invece di aziendaspaspa.com, oppure azienda.co invece di azienda.com).
- **Punycode / homograph attack**: si registra un dominio che utilizza caratteri Unicode (es. cirillici o greci) visivamente identici a lettere latine, che il browser o il client email possono mostrare come se fossero il dominio originale (vedi approfondimento sotto).
- **Account email realmente compromesso**: il truffatore non finge un dominio simile, ma accede realmente alla casella email di uno dei due interlocutori (tramite phishing o data breach) e scrive da lì, rendendo l'inganno ancora più difficile da riconoscere.
- **Momento scelto ad arte**: il messaggio con il "nuovo IBAN" arriva tipicamente a ridosso di un pagamento già concordato, con tono di urgenza, per non lasciare il tempo di verificare con calma.

Una volta ricevuto il bonifico sul conto indicato dal truffatore, i fondi vengono spesso spostati e nascosti rapidamente attraverso più passaggi (conti "mulo", cambio in criptovalute e uso di mixer/tumbler — vedi sezione 11) per disperdere le tracce del denaro prima che la vittima si accorga della frode.

Come difendersi (procedura pratica)

1. **Verificare sempre fuori dal canale email** qualunque richiesta di cambio IBAN o pagamento urgente: una telefonata al numero già noto dell'azienda (non quello scritto nella mail sospetta) basta a smascherare la quasi totalità di questi tentativi.
2. **Controllare il dominio del mittente carattere per carattere**, non solo il nome visualizzato: molti client email mostrano solo il nome del mittente, nascondendo l'indirizzo reale.
3. **Diffidare dei toni di urgenza** ("paga entro oggi", "cambio banca improvviso", "non chiamare, sono in riunione").
4. **Verificare gli header dell'email** (vedi procedura a inizio sezione) se il dominio appare sospetto.

Punycode: cos'è e come proteggersi

Il **Punycode** è un sistema che converte caratteri Unicode (lettere accentate, cirilliche, greche, ecc.) in una stringa ASCII compatibile con il sistema dei nomi a dominio (DNS), che nasce per gestire correttamente i domini internazionali (es. città o nomi non scritti in alfabeto latino). Un dominio in Punycode è riconoscibile dal prefisso xn--.

Il problema nasce quando questo meccanismo viene sfruttato per il **homograph attack** (attacco omografico): un truffatore registra un dominio con caratteri Unicode che, visivamente, sono identici o quasi identici a lettere latine (es. una "a" cirillica al posto della "a" latina). Il browser o il client di posta, per rendere leggibile il dominio, lo decodifica e lo mostra come se fosse il dominio originale — rendendo la truffa quasi impossibile da notare a occhio nudo, anche controllando l'URL con attenzione.

Come difendersi dal Punycode/homograph attack:

- **Forzare la visualizzazione in Punycode nel browser.** Alcuni browser, per impostazione predefinita, decodificano e mostrano il dominio nella sua forma "leggibile" anche quando contiene caratteri Unicode sospetti — nascondendo così il prefisso xn-- che tradirebbe l'inganno. Su Firefox, ad esempio, è possibile forzare la visualizzazione sempre in Punycode impostando su true il parametro `network.IDN_show_punycode` nelle impostazioni avanzate (`about:config`). Chrome e Safari applicano già filtri nativi di protezione simili, ma restano meno configurabili manualmente.
- **Usare estensioni del browser che rilevano mix di alfabeti anomali.** Esistono estensioni di sicurezza che analizzano in tempo reale i caratteri di una pagina e segnalano/bloccano la navigazione se rilevano un mix sospetto di alfabeti diversi in uno stesso dominio (es. caratteri cirillici mescolati a caratteri latini) — un pattern tipico di un attacco omografico.
- **In caso di dubbio su un link, scomporlo nei suoi caratteri Unicode.** Uno strumento come **CyberChef** (tramite la sua funzione integrata per la conversione a/da Punycode) permette di analizzare un URL sospetto ed evidenziare esattamente quali caratteri Unicode lo compongono, rendendo visibile un'eventuale sostituzione di caratteri altrimenti indistinguibile a occhio.
- Non cliccare mai direttamente su link ricevuti via email per l'accesso a servizi sensibili (banca, email aziendale, ecc.): digitare manualmente l'indirizzo noto nel browser resta il metodo più sicuro.
- Verificare i certificati SSL del sito (vedi sezione 1): un dominio truffaldino può comunque avere un certificato SSL valido (chiunque può ottenerne uno), quindi il lucchetto del browser da solo non è garanzia di autenticità — va sempre controllato il nome del dominio.

CyberChef	Sito web consultabile	Suite di strumenti per l'analisi e la trasformazione di dati, utile anche per convertire e scomporre domini Punycode/Unicode e verificarne l'autenticità.
Punycode Warning	Estensione browser (Google Chrome)	Mostra un avviso quando si visita un dominio che utilizza la codifica Punycode, segnalando un potenziale rischio di homograph attack.
PunyCode Domain Detection	Estensione browser (Mozilla Firefox)	Analizza i domini visitati per rilevare tentativi di phishing basati su Punycode e caratteri Unicode.

Queste sono solo alcune delle estensioni disponibili in questo ambito: è sempre consigliabile cercare quelle più aggiornate al momento del bisogno, poiché nel tempo possono nascerne di nuove o essere sostituite da alternative migliori.

10 NUMERI DI TELEFONO

Concetti di base

- Un numero di telefono può essere una **linea mobile/fissa reale** oppure un **numero VoIP** (Voice over IP), spesso usato per anonimato o per servizi temporanei.
- In Italia esiste un servizio ufficiale, l'**Override**, previsto dal Codice della Privacy (Art. 127): se si riceve una chiamata con numero anonimo ("Numero Privato"/"Sconosciuto"), attivando in anticipo questo servizio con il proprio gestore, il telefono mostrerà il numero reale del chiamante. Non è retroattivo: va richiesto prima (modulo + pagamento, circa 26-30€ secondo l'operatore) e resta attivo per un massimo di 15 giorni.

Procedura pratica: ricerca OSINT su un numero di telefono

1. **Verificare se è VoIP o un numero reale:** usare un servizio di HLR Lookup, NumVerify o Twilio Lookup API per ottenere operatore e tipo di linea.
2. **Salvare il numero in rubrica** per vedere se sono visibili un nome o una foto profilo pubblici su WhatsApp, Telegram o altre app collegate.
3. **Cercare il numero su Google tra virgolette** ("+39...") per trovare aziende, profili pubblici o citazioni online.
4. **Verificare se è registrato su servizi specifici** tramite i tool dedicati elencati sotto.

Strumenti

Phonelfoga	Tool utilizzabile su Kali Linux	Raccoglie informazioni su numeri di telefono (operatore, tipo di linea, geolocalizzazione parziale). Da usare da terminale Linux.
Ignorant	Tool utilizzabile su Kali Linux	Verifica su quali app/social (WhatsApp, Instagram, ecc.) è registrato un numero di telefono.
HLR Lookup	Sito web consultabile / servizio	Verifica se un numero è VoIP o una linea mobile reale.
NumVerify	Sito web consultabile / API	Restituisce operatore e tipo di linea di un numero.
Twilio Lookup API	Servizio/API	Fornisce carrier e tipologia di linea.
Free Carrier Lookup	Sito web consultabile	Tra i migliori servizi gratuiti per numeri VoIP: indica la società che gestisce il numero.
numberingplans.com	Sito web consultabile	Analisi utenze telefoniche, IMSI, IMEI, ICCID.
Sync.Me	Sito web consultabile e app mobile	Ricerca informazioni associate a un numero di telefono.
Truecaller	App mobile (Android e iPhone) e sito web	Identificazione chiamante e reverse lookup di numeri di telefono tramite un ampio database crowdsourced (nome associato, localizzazione, segnalazioni di spam). Punto di forza: copre bene i numeri mobili, storicamente poco presenti negli elenchi tradizionali. Limite: la qualità del risultato dipende dai dati condivisi dagli altri utenti dell'app; per ricerche passive è preferibile un account dedicato invece dell'account personale.

11 USERNAME E PRESENZA SOCIAL

Concetti di base

- Un **username** (nome utente) è spesso riutilizzato dalla stessa persona su più piattaforme diverse: individuarlo su un servizio permette potenzialmente di risalire a tutti gli altri profili collegati.
- Strumenti come Sherlock automatizzano questa ricerca controllando centinaia di piattaforme in un'unica esecuzione.

Procedura pratica: ricerca OSINT su un username

1. Eseguire una ricerca automatizzata su più piattaforme (Sherlock, Blackbird, Tookie OSINT).
2. Verificare manualmente la disponibilità/esistenza dello stesso username su siti di verifica dedicati (namechk.com, namecheckup.com).
3. Incrociare i risultati con le sezioni "Social Network per piattaforma" (sezione 6) per approfondire ogni singolo profilo trovato.

Strumenti

Sherlock	Tool utilizzabile su Kali Linux	Ricerca di un username su centinaia di piattaforme social contemporaneamente.
Blackbird	Tool utilizzabile su Kali Linux	Ricerca OSINT su username ed email; verifica la presenza social di un utente.
Tookie OSINT	Tool utilizzabile su Kali Linux	Ricerca di username con funzionalità simili a Sherlock.
Ignorant	Tool utilizzabile su Kali Linux	Enumerazione e analisi di username (oltre all'uso su numeri di telefono, vedi sezione 4).
user-scanner	Tool utilizzabile su Kali Linux	Individua su quali piattaforme è registrato un determinato username.
namechk.com	Sito web consultabile	Verifica disponibilità/esistenza di un username su molte piattaforme diverse.
namecheckup.com	Sito web consultabile	Analoga funzione di verifica username multi-piattaforma.

Ricerca utenti o gruppi Telegram:

- Su Google: `site:t.me nomeutente`
- Oppure tramite la ricerca interna di Telegram stessa.

TGStat	Sito web consultabile	Piattaforma di analisi per canali e gruppi Telegram pubblici: crescita iscritti, statistiche di engagement, categorie e ranking. Particolarmente efficace su canali in lingua russa/area CIS. Usare un account di ricerca dedicato, non quello personale.
Telemetr.io	Sito web consultabile	Analoga a TGStat, con analisi più approfondita a livello di singolo post e mappatura delle reti di inoltra (forwarding) tra canali — utile per risalire a canali collegati tra loro.
Lyzem / Telegago	Sito web consultabile	Motori di ricerca dedicati che indicizzano i messaggi pubblici di Telegram, utili per cercare parole chiave o frasi specifiche all'interno di canali e gruppi pubblici.

12 SOCIAL NETWORK PER PIATTAFORMA

Concetti di base

- Molti social network associano a ogni account un identificativo numerico univoco (ID), spesso presente o ricavabile dal codice sorgente della pagina, dalle API o da altre risorse pubbliche. A differenza dello username, che in alcuni casi può essere modificato, l'ID tende a essere più stabile nel tempo e può risultare utile per identificare con maggiore precisione un profilo.
- Alcuni strumenti descritti in questa sezione raccolgono automaticamente informazioni già pubblicamente accessibili da profili o pagine. L'utilizzo di tali strumenti può essere in contrasto con i Termini di Servizio delle piattaforme interessate, che spesso limitano o vietano l'automazione e il data scraping non autorizzati. La violazione dei Termini di Servizio non coincide necessariamente con la commissione di un reato, ma può comportare conseguenze contrattuali, tecniche o legali a seconda della normativa applicabile e delle circostanze. L'uso di questi strumenti resta sotto la piena responsabilità dell'utilizzatore, che dovrebbe limitarsi alla raccolta e all'analisi di informazioni rese pubblicamente disponibili nel rispetto della normativa vigente.

Procedura pratica: trovare l'ID numerico di un profilo

ID Instagram:

1. Vai sul profilo Instagram in esame (usando Google Chrome).
2. Tasto destro sulla pagina → "Visualizza sorgente pagina".
3. Ctrl + F e cerca il testo `profilePage_`.
4. Il numero subito dopo è l'ID utente Instagram.

ID Facebook:

1. Vai sulla pagina del profilo in esame da computer.
2. Tasto destro in un punto vuoto → "Ispeziona" o "Visualizza sorgente pagina".
3. Ctrl + F (Windows) o Cmd + F (Mac) e cerca `profile_id`.
4. Il numero subito dopo è l'ID Facebook cercato.
5. In alternativa, usare direttamente il sito lookup-id.com.

Strumenti per piattaforma

Instagram

Instaloader	Tool utilizzabile su Kali Linux	Download e analisi di contenuti pubblici da profili Instagram.
Osintgram	Tool utilizzabile su Kali Linux	OSINT su Instagram: raccolta di informazioni su follower, post e dati pubblici del profilo.
Toutatis	Tool utilizzabile su Kali Linux (gratuito)	Estrae informazioni da un account Instagram tramite username o ID numerico: metadati del profilo, follower/following, biografia, e in alcuni casi contatti pubblicamente esposti come email ed alcune cifre del numero di telefono. Punto di forza: interrogazione rapida da riga di comando. Limite: richiede un cookie di sessione Instagram per funzionare, e i dati di contatto sono recuperabili solo se effettivamente esposti dall'account target.
IG Follower Export Tool	Sito web consultabile (richiede login)	Esporta la lista follower di un profilo Instagram.
StoriesIG	Sito web consultabile	Visualizza/scarica storie Instagram pubbliche in modo anonimo.

Instahunt	Sito web consultabile	Geolocalizza contenuti Instagram pubblici.
lookup-id.com	Sito web consultabile	Trova l'ID numerico associato a un profilo Instagram/Facebook.

Facebook

fdown.net	Sito web consultabile	Download di video pubblici da Facebook.
Facebook Comment Extractor	Sito web consultabile	Estrae i commenti pubblici da un post Facebook.

TikTok

Bellingcat TikTok Timestamp	Sito web consultabile	Estrae la data/ora esatta di creazione di un video TikTok dal suo ID, utile per verifiche temporali.
MaveKite	Sito web consultabile	Analisi di profili e contenuti pubblici TikTok: statistiche di un account, andamento dei contenuti nel tempo e dati aggregati utili a inquadrare l'attività di un profilo.

YouTube

Citizen Evidence	Sito web consultabile	Tool di verifica per video YouTube (Amnesty International): mostra thumbnail, data di upload e metadati per verifiche investigative/giornalistiche.
Yoodownload	Sito web consultabile	Download di video YouTube.

OnlyFans

OnlyFinder	Sito web consultabile	Motore di ricerca per trovare account OnlyFans pubblici a partire da nome, username o altre informazioni.
-------------------	-----------------------	---

LinkedIn

ContactOut	Sito web consultabile	Ricerca di informazioni su profili LinkedIn.
-------------------	-----------------------	--

13 IMMAGINI, METADATI E GEOSINT

Concetti di base

- I **metadati EXIF** di una foto possono contenere data di scatto, modello del dispositivo e, se il GPS era attivo, le coordinate esatte di dove è stata scattata.
- Le foto **mantengono** i metadati EXIF quando inviate per email o quando racchiuse in un file ZIP.
- Le foto **perdono** i metadati EXIF quando inviate tramite WhatsApp o Telegram (le piattaforme le ricomprimono e li rimuovono).
- Anche i **social network** (Instagram, Facebook, ecc.) rimuovono automaticamente i metadati EXIF dalle foto al momento della pubblicazione, per motivi di privacy e ottimizzazione.
- Le coordinate GPS estratte con EXIF sono tipicamente in formato **DMS** (gradi, minuti, secondi).

Procedura pratica: workflow di analisi di immagini e video

1. **Analizza i metadati EXIF** con ExifTool (se disponibili).
2. Se emergono **coordinate GPS**, inseriscile su Google Maps, Google Earth Pro o Google Street View
3. Se il materiale è un **video**, scomponilo in fotogrammi con VLC Media Player (Strumenti → Acquisizione fotogrammi) per isolare dettagli come insegne, targhe, palazzi e arredo urbano.
4. Esegui una **ricerca visiva inversa** dell'immagine (Yandex Images, Google Images, Picarta AI) concentrandoti sul luogo — edifici, strade, montagne, arredo urbano — non sulla persona. Yandex tende a restituire risultati più utili dal punto di vista geografico rispetto a Google.
5. **Confronta gli indizi raccolti con le mappe**: Google Maps/Street View, Google Earth Pro (fondamentale per confronto storico e vista 3D), ESRI Wayback (immagini satellitari storiche), OverPass Turbo (dati OpenStreetMap avanzati).
6. Usa Street View in modo sistematico: confronta balconi, pali, segnali stradali, tombini, alberi.
7. Osserva i **dettagli chiave**: targhe straniere (paese, colori, font, formati), sottobicchieri/menu/loghi di bar e locali, attività commerciali (verificabili su TripAdvisor confrontando le foto degli utenti).
8. Verifica quanto trovato con fonti esterne (TripAdvisor, OpenStreetMap, immagini storiche).

Procedura pratica: estrazione delle coordinate GPS

1. per leggere i metadati GPS della foto.exiftool nomefile.jpgEsegui
2. Incolla la coordinata ottenuta su Google Maps,

Strumenti — Metadati

ExifTool	Tool utilizzabile su Kali Linux (disponibile anche per Windows/Mac)	Analisi ed estrazione di metadati da immagini, video e documenti; legge anche le coordinate GPS.
Exif Data Viewer	Sito web consultabile	Permette di caricare direttamente una foto e visualizzarne i metadati.
exif.tools	Sito web consultabile	Visualizzatore metadati EXIF online.
metadataviewer.com	Sito web consultabile	Visualizzatore metadati online alternativo.
FotoForensics	Sito web consultabile	Analisi forense di immagini: metadati e individuazione di eventuali manipolazioni.

Strumenti — Ricerca inversa e geolocalizzazione da immagini

Google Images	Sito web consultabile	Ricerca inversa generale di immagini.
Yandex Images	Sito web consultabile	Il più efficace per riconoscimento di luoghi e volti tra i motori di ricerca immagini.
TinEye	Sito web consultabile	Traccia la storia e le versioni precedenti di un'immagine sul web.
Picarta AI	Sito web consultabile	Stima la posizione geografica in cui è stata scattata una foto tramite intelligenza artificiale.

Strumenti — Mappe e confronto geografico

Google Maps / Street View	Sito web consultabile	Mappa e vista stradale per confronto visivo con l'immagine originale.
Google Earth Pro	Software desktop (Windows/Mac/Linux)	Versione avanzata di Google Earth: confronto storico, vista 3D, strumenti di misurazione.
ESRI Wayback	Sito web consultabile	Immagini satellitari storiche per confronto temporale di un'area.
Satellites.pro	Sito web consultabile	Confronto rapido tra mappe satellitari diverse.
OverPass Turbo	Sito web consultabile	Interrogazione avanzata dei dati OpenStreetMap.
coordinate-gps.it	Sito web consultabile	Inserendo coordinate GPS, mostra il punto esatto sulla mappa.

Strumenti — Editing e supporto immagini/video

GIMP	Software desktop (Windows/Mac/Linux)	Editor di immagini gratuito: utile per ingrandire, ritagliare o migliorare un dettaglio prima di una ricerca inversa (es. su Google Lens).
VLC Media Player	Software desktop (Windows/Mac/Linux)	Player multimediale con funzione di acquisizione fotogrammi da video.

Concetti di base

- **100% anonimato online non esiste:** anche usando VPN e Tor insieme, restano tracce e tecniche che possono ricondurre a un utente.
- Gli elementi che possono collegare un'attività online a una persona/dispositivo sono principalmente: l'indirizzo IP fornito dal provider, i log dei siti/servizi visitati, gli orari di accesso, e il **fingerprint** del browser/dispositivo.
- **Il fingerprinting** è una tecnica che consente di riconoscere un dispositivo o un browser raccogliendo una serie di informazioni tecniche, come il sistema operativo, il browser utilizzato, i font installati, la risoluzione dello schermo, la lingua e altre caratteristiche. Anche in assenza di cookie, la combinazione di questi elementi genera un'"impronta digitale" (fingerprint) spesso sufficientemente distintiva da permettere di riconoscere lo stesso dispositivo nel tempo e su siti diversi, rendendo più difficile una navigazione completamente anonima.

Ad esempio, una persona può creare cinque account con nomi differenti. Se accede sempre dallo stesso dispositivo, il browser trasmetterà lo stesso fingerprint. Gli investigatori possono quindi osservare che tutti gli account sembrano provenire dal medesimo dispositivo e collegarli tra loro. Il fingerprint, tuttavia, non identifica direttamente una persona: rappresenta un elemento tecnico che, insieme ad altre informazioni (come indirizzo IP, orari di accesso o dati forniti dai servizi online), può contribuire all'identificazione dell'utilizzatore.

Procedura pratica: aumentare l'anonimato in navigazione

1. **Usare VPN + rete Tor insieme.** Tra le VPN con policy no-log affidabili: **Proton VPN, NordVPN, Mullvad VPN.**
2. **Accedere alla rete Tor** tramite Tor Browser, oppure — su Linux — con tool che instradano automaticamente tutto il traffico di sistema via Tor: **TorGhost, AnonSurf, ProxyChains, Nipe** (la scelta tra questi dipende da preferenza personale/comodità d'uso).
3. **Contrastare il fingerprinting:**
 - Usare browser orientati alla privacy (Tor Browser, oppure Firefox con impostazioni anti-tracciamento).
 - Disattivare o limitare JavaScript quando possibile.
 - Bloccare cookie e tracker di terze parti.
 - Evitare troppe estensioni o personalizzazioni eccessive del browser: paradossalmente rendono l'impronta più unica e riconoscibile, non meno.
1. **Farsi guidare da un'AI** (es. Claude, ChatGPT): per le impostazioni specifiche anti-fingerprint di un browser, un'AI può fornire passo passo i comandi e le configurazioni aggiornate del momento, evitando di affidarsi a guide statiche che con il tempo diventano obsolete.

Modalità di installazione di una distribuzione Linux

Una distribuzione Linux può essere utilizzata in diversi modi, con implicazioni diverse sul piano dell'anonimato:

- **Come sistema operativo principale:** installata direttamente sul disco del computer, sostituendo (o affiancando) il sistema operativo esistente.
- **In dual boot:** installata sul disco insieme a un altro sistema operativo (es. Windows), scegliendo quale avviare a ogni accensione del computer.
- **Su USB persistente:** il sistema gira da una chiavetta USB, ma salva le modifiche (file, configurazioni, cronologia) in una partizione dedicata sulla stessa chiavetta, che quindi "ricorda" tra un utilizzo e l'altro.
- **Su USB live (non persistente):** il sistema gira interamente in RAM a partire dalla chiavetta USB, senza scrivere nulla in modo permanente; a ogni riavvio, tutto torna come all'inizio.

Perché una USB live è generalmente più anonima di una persistente: una configurazione persistente, proprio perché salva dati (cronologia, file, impostazioni), lascia più margine all'errore umano — è possibile, per distrazione, lasciare accidentalmente tracce recuperabili (es. un file scaricato e non cancellato, una cronologia non svuotata,

una configurazione di rete non ripristinata). Una sessione live, azzerando tutto a ogni riavvio, riduce drasticamente questo tipo di rischio: non c'è nulla da "dimenticare" di cancellare, perché nulla viene salvato in partenza.

Un'altra opzione: la macchina virtuale. Una distribuzione Linux può essere provata anche all'interno di una **macchina virtuale**, tramite software come **VirtualBox**: si tratta di un "computer simulato" che gira come programma all'interno del sistema operativo principale, permettendo di installare e usare Linux (o Tails) senza modificare in alcun modo il computer host. È un buon modo per fare pratica in un ambiente isolato, anche se — a differenza di una USB live — la macchina virtuale gira comunque all'interno del sistema operativo principale, che resta quindi un fattore da considerare nel bilancio complessivo dell'anonimato.

Tails OS

Tra gli strumenti per l'anonimato, quello che — nella mia esperienza personale e in base a quanto ho studiato — considero al momento il più efficace per un anonimato elevato è **Tails OS**. Questo non è da intendersi come un giudizio assoluto o definitivo, ma come una valutazione personale basata sull'uso e sullo studio di questo strumento; ognuno è libero di valutare e scegliere gli strumenti più adatti alle proprie esigenze.

Tails (The Amnesic Incognito Live System) è una distribuzione Linux pensata specificamente per l'anonimato, distribuita esclusivamente in modalità live USB (non è progettata per un'installazione persistente o come sistema operativo principale). Le sue caratteristiche principali:

- **Instrada tutto il traffico attraverso Tor di default:** non serve configurare nulla, ogni connessione a internet passa automaticamente attraverso la rete Tor.
- **È "amnesica":** funziona interamente in RAM e non scrive nulla sul disco del computer che la ospita. Allo spegnimento, la RAM viene azzerata e non resta alcuna traccia della sessione sul computer usato, a meno di non aver esplicitamente attivato e usato uno spazio di archiviazione persistente cifrato (opzionale).
- **Riduce l'errore umano nella configurazione:** essendo già preconfigurata di default per l'anonimato (routing forzato via Tor, nessun salvataggio automatico), elimina gran parte dei rischi legati a una configurazione manuale imperfetta che potrebbe lasciare tracce per errore.
- **È lo strumento storicamente scelto da giornalisti e whistleblower** che lavorano con materiale sensibile (è noto, ad esempio, il suo utilizzo da parte di giornalisti coinvolti nel caso Snowden), proprio per l'affidabilità del suo modello "nessuna traccia".

Come per ogni strumento di anonimato, anche Tails non garantisce un anonimato assoluto (vedi concetti di base a inizio sezione): resta comunque vulnerabile, ad esempio, a compromissioni a livello di firmware del computer host o a errori di utilizzo (come inserire credenziali reali durante una sessione).

Browser orientati alla privacy

Oltre a Tor Browser — che resta lo strumento di riferimento quando serve il massimo livello di anonimato e protezione — esistono altri browser pensati per offrire una buona tutela della privacy nell'uso quotidiano, pur senza instradare il traffico attraverso la rete Tor:

- **LibreWolf:** una versione di Firefox modificata per rimuovere la telemetria e irrobustire di default le impostazioni sulla privacy, mantenendo però l'esperienza d'uso classica di Firefox.
- **Brave:** browser basato su Chromium con blocco di annunci e tracker integrato di default; è un'opzione solida per un uso quotidiano bilanciato tra privacy e comodità, pur non raggiungendo il livello di anonimato di Tor.
- **Mullvad Browser:** sviluppato in collaborazione tra Mullvad (VPN) e il Tor Project, riprende molte delle protezioni anti-fingerprinting di Tor Browser ma si connette al normale clear web anziché alla rete Tor; è indicato per chi vuole una forte resistenza al fingerprinting abbinata a un utilizzo più simile alla navigazione tradizionale (idealmente insieme a una VPN).
- **Firefox:** nella configurazione predefinita non offre lo stesso livello di protezione degli altri browser elencati, ma se configurato correttamente (disattivando telemetria, rafforzando le impostazioni sulla privacy, aggiungendo estensioni dedicate) può comunque offrire un buon livello di tutela.

In sintesi: per un utilizzo quotidiano con una buona protezione della privacy, questi browser sono valide alternative; quando invece serve il massimo dell'anonimato, **Tor Browser rimane lo strumento di riferimento**.

Tor Browser

Tor Browser garantisce l'anonimato attraverso tre meccanismi principali:

- **Onion Routing:** i dati vengono cifrati a più livelli, come gli strati di una cipolla. Ogni nodo della rete rimuove solo uno strato di cifratura, conoscendo esclusivamente il passaggio precedente e quello successivo, senza avere una visione completa della comunicazione.
- **Tre nodi casuali:** il traffico viene fatto passare attraverso tre server Tor scelti casualmente (ingresso, intermedio, uscita), separando l'identità dell'utente dalla destinazione finale.
- **Protezione locale:** Tor elimina automaticamente cookie e cronologia per ridurre le tracce lasciate sul dispositivo.

Tuttavia, Tor **non garantisce anonimato assoluto**: un utente può essere identificato sfruttando errori personali o vulnerabilità della rete.

Principali metodi di identificazione

1. Errori dell'utente (OpSec)

L'anonimato può fallire se l'utente:

- inserisce informazioni reali (email, nickname o password);
- utilizza sistemi di pagamento tracciabili, come alcune criptovalute non anonime.

2. Controllo dei nodi Tor

Chiunque può creare un nodo Tor, compresi ricercatori, aziende, volontari, autorità o soggetti malevoli.

Possibili attacchi:

- **Nodi di uscita controllati:** un gestore può intercettare il traffico non cifrato (ad esempio siti HTTP senza HTTPS) e leggere i dati trasmessi.
- **Attacco di temporizzazione (Timing Attack):** se un soggetto controlla contemporaneamente il nodo di ingresso e quello di uscita, può confrontare orari e quantità di dati per collegare l'utente reale all'attività anonima.

Esempio:

- Il nodo di ingresso registra che Mario si connette a Tor alle 10:00.
- Il nodo di uscita registra che un utente anonimo visita un sito illegale alle 10:00 trasferendo 5 MB.
- Confrontando questi dati, è possibile associare l'attività a Mario.

Chi gestisce i nodi Tor?

I nodi possono essere gestiti da:

- volontari interessati alla privacy;
- università e centri di ricerca;
- ONG e organizzazioni per i diritti digitali;
- aziende tecnologiche;
- Autorità come Polizia o soggetti che cercano di analizzare il traffico.

Il **Tor Project** controlla la rete tramite test automatici e verifiche sui nodi più importanti (come i nodi Guard, cioè i nodi di ingresso), cercando di ridurre il rischio di abusi.

Perché un solo nodo non basta per identificare un utente?

Controllare un solo nodo non è sufficiente:

- **Nodo di ingresso:** permette di vedere l'indirizzo IP reale dell'utente, ma non la destinazione del traffico.
- **Nodo di uscita:** permette di vedere la destinazione della comunicazione, ma non l'identità dell'utente.

Per identificare qualcuno servirebbe controllare entrambi i punti della connessione e applicare un attacco di temporizzazione. Questa situazione è difficile perché Tor sceglie casualmente i nodi tra migliaia di server distribuiti nel mondo.

Strumenti

Proton VPN	Servizio VPN	VPN con policy no-log, tra le più consigliate per l'anonimato.
NordVPN	Servizio VPN	VPN con policy no-log.
Mullvad VPN	Servizio VPN	VPN con policy no-log, orientata fortemente alla privacy.
Tor Browser	Software desktop	Browser che instrada la navigazione attraverso la rete Tor.
Tails OS	Distribuzione Linux (live USB)	Sistema live orientato all'anonimato: instrada tutto il traffico via Tor di default e non lascia traccia sul computer host allo spegnimento.
VirtualBox	Software desktop (Windows/Mac/Linux)	Software di virtualizzazione che permette di eseguire una distribuzione Linux (o altro OS) in una macchina virtuale, senza modificare il sistema operativo principale.
LibreWolf	Software desktop	Fork di Firefox orientato alla privacy, senza telemetria e con impostazioni rafforzate di default.
Brave	Software desktop / app mobile	Browser basato su Chromium con blocco di tracker e annunci integrato di serie.
Mullvad Browser	Software desktop	Browser con protezioni anti-fingerprinting derivate da Tor Browser, ma orientato al normale clear web.
TorGhost	Tool utilizzabile su Kali Linux	Instrada tutto il traffico di sistema attraverso la rete Tor.
AnonSurf	Tool utilizzabile su Kali Linux	Anonimizza il traffico di sistema instradandolo via Tor.
ProxyChains	Tool utilizzabile su Kali Linux	Instrada il traffico attraverso una catena di proxy/Tor.
Nipe	Tool utilizzabile su Kali Linux	Instrada tutto il traffico di rete attraverso Tor.
uBlock Origin	Estensione browser	Blocca tracker e script pubblicitari/di tracciamento.
Privacy Badger	Estensione browser	Blocca automaticamente il tracciamento rilevato durante la navigazione.
CanvasBlocker	Estensione browser	Limita il fingerprinting basato su Canvas (tecnica di identificazione tramite rendering grafico del browser).
NoScript	Estensione browser	Blocca l'esecuzione di JavaScript; molto efficace contro il tracciamento ma meno pratico nell'uso quotidiano.

15 VEICOLI E TARGHE

Concetti di base

- Un'app di scansione targhe permette di risalire rapidamente al paese di immatricolazione e ad alcune informazioni pubbliche associate a una targa, semplicemente fotografandola.

Strumenti

Targa Scan	App mobile (Apple e Android)	Riconosce e identifica targhe automobilistiche tramite fotocamera del telefono.
ACI Space	App mobile (Apple e Android)	App ufficiale dell'Automobile Club d'Italia; tramite la funzione "Infotarga" permette di ottenere informazioni su un veicolo a partire dalla targa (modello, dati tecnici, eventuali vincoli al PRA).
iTarga	App mobile	Riconoscimento e informazioni su targhe automobilistiche.

Controllo veicoli rubati

Ricerca targhe e telai rubati/smarriti (CRIMNET)	Sito web consultabile	Portale della Polizia di Stato (crimnet.dcpic.interno.gov.it) per verificare se una targa o un numero di telaio risultano segnalati come rubati o smarriti.
---	-----------------------	---

16 STRUMENTI DI PAGAMENTO (IBAN E CARTE)

Concetti di base

- L'**IBAN** contiene al suo interno il codice ABI (banca) e CAB (filiale), risalibili con appositi calcolatori online.
- Il **BIN (Bank Identification Number)** corrisponde alle prime 6-8 cifre di una carta di pagamento e identifica esclusivamente: circuito (Visa, Mastercard, ecc.), istituto emittente, tipologia di carta (debito, credito, prepagata) e paese di rilascio.
- Un BIN checker è uno strumento di **fraud prevention**: viene usato ad esempio dagli e-commerce per verificare la coerenza tra il paese del BIN e il paese di fatturazione dichiarato in un ordine, individuando pattern sospetti.

Procedura pratica

1. Per un IBAN, verificarlo su un calcolatore IBAN online per risalire a banca e filiale di appartenenza.
2. Per una carta di pagamento, estrarre le prime 6-8 cifre (BIN) e verificarle su un servizio di BIN lookup per ottenere circuito, banca emittente, tipologia e paese.

Strumenti — Verifica IBAN

codicibancari.it/iban	Sito web consultabile	Verifica un IBAN e la banca associata.
it.ibancalculator.com	Sito web consultabile	Verifica un IBAN e la banca associata.
codiceiban.it	Sito web consultabile	Calcola e verifica IBAN, trova codice ABI/CAB, trova la banca da ABI/CAB o da IBAN.

Strumenti — BIN checker (carte di pagamento)

bincodes.com	Sito web consultabile	BIN checker: verifica circuito, istituto emittente, tipologia di carta e paese di rilascio a partire dal BIN.
exactbins.com	Sito web consultabile	BIN checker analogo: verifica circuito, istituto emittente, tipologia di carta e paese di rilascio.

17 ALTRI SERVIZI PUBBLICI ITALIANI

Concetti di base

- L'Agenzia delle Entrate e l'Anagrafe Nazionale della Popolazione Residente (ANPR) offrono servizi pubblici di verifica su codice fiscale, partita IVA e certificati anagrafici.

Strumenti — Agenzia delle Entrate

Attraverso il sito dell'Agenzia delle Entrate è possibile verificare: codice fiscale, partita IVA (anche comunitaria), contrassegni telematici, codice identificativo dei contratti di locazione, professionisti abilitati all'apposizione del visto di conformità, documenti con "glifo" inviati dall'Agenzia.

Strumenti — Anagrafe Nazionale (ANPR)

All'interno del portale ANPR è possibile scaricare online e gratuitamente, per sé stessi o per terzi tramite delega, i seguenti certificati: anagrafico di nascita, anagrafico di matrimonio, di cittadinanza, di esistenza in vita, di residenza, di residenza AIRE, di stato civile, di stato di famiglia, di stato di famiglia e stato civile, di residenza in convivenza, di stato di famiglia AIRE, di stato di famiglia con rapporti di parentela, di stato libero, anagrafico di unione civile, di contratto di convivenza.

Altri servizi pubblici italiani utili

numberingplans.com	Analisi di utenze telefoniche, IMSI, IMEI, ICCID (vedi anche sezione 4).
Verifica posizione permesso di soggiorno (portale Questure.it)	Verifica dello stato di una pratica di permesso di soggiorno tramite ricevuta Poste.

18 DATA BREACH E DATI TRAPELATI (LEAKS)

Concetti di base

- Un **data breach** (violazione di dati) è un incidente in cui informazioni riservate (email, password, dati personali) vengono sottratte da un servizio online e rese pubbliche o messe in vendita.
- Chi ha intenzioni malevole spesso ottiene questi dati acquistandoli o scambiandoli su forum e marketplace criminali, incluso il dark web, e li utilizza per il **credential stuffing**: provare le stesse credenziali trapegate su altri siti/app dove la vittima potrebbe essersi registrata con la stessa combinazione email/password.
- Per questo motivo è sempre consigliabile usare **password diverse per ogni account**: in caso di data breach su un singolo servizio, le altre registrazioni restano al sicuro.
- **Password Manager**: con decine o centinaia di servizi online diversi, ricordare a memoria una password unica e complessa per ciascuno è praticamente impossibile. Un **Password Manager** risolve il problema: è un'applicazione che genera e conserva in modo sicuro (cifrato) tutte le credenziali, rendendole accessibili tramite un'unica password principale da ricordare. Tra le opzioni gratuite e multiplatforma (disponibili sia su Android che su iPhone, oltre che su computer) più diffuse e affidabili al momento: **Bitwarden** (open source, senza limiti su numero di password o dispositivi nel piano gratuito), **Proton Pass** (dal team di Proton Mail, anch'esso con piano gratuito senza limiti su password e dispositivi).
- **Nota legale**: l'utilizzo di servizi come Have I Been Pwned per verificare se il proprio indirizzo email sia stato coinvolto in una violazione di dati non presenta, di per sé, profili di illiceità: si tratta infatti di strumenti creati proprio con la finalità di consentire agli utenti di verificare l'eventuale esposizione delle proprie informazioni.

Diversa è invece la situazione in cui si accede, si acquisisce, si scarica o si diffonde il contenuto integrale di un archivio di dati sottratti a terzi (ad esempio database contenenti password o altre informazioni riservate). In tali casi, la responsabilità può dipendere dalle modalità di ottenimento dei dati e dal loro successivo utilizzo, con possibili conseguenze sia sotto il profilo penale sia in relazione alla normativa in materia di protezione dei dati personali, inclusi il GDPR e il Codice Privacy.

Procedura pratica

1. Verificare se un'email è comparsa in breach noti tramite Have I Been Pwned.
2. Approfondire con IntelligenceX (previa registrazione) per informazioni aggiuntive sui breach.
3. Consultare Library of Leaks per ricerche più mirate su dati trapeitati specifici (archivio di dati pubblici/leak: usare solo per finalità lecite e nel rispetto della normativa vigente)

Strumenti

Have I Been Pwned	Sito web consultabile	Verifica se un'email è comparsa in data breach noti (vedi anche sezione 3).
IntelligenceX	Sito web consultabile (richiede registrazione)	Motore di ricerca OSINT su leak e data breach; spesso restituisce più informazioni rispetto ad altri servizi simili.
Library of Leaks	Sito web consultabile	Archivio di dati trapeitati consultabile per ricerche mirate (archivio di dati pubblici/leak: usare solo per finalità lecite e nel rispetto della normativa vigente)
Bitwarden	App multiplatforma (Android, iPhone, desktop, browser)	Password Manager gratuito e open source, senza limiti su password o dispositivi nel piano free.
Proton Pass	App multiplatforma (Android, iPhone, desktop, browser)	Password Manager gratuito del team di Proton Mail, con piano free senza limiti su password e dispositivi.

19 CRIPTOVALUTE

Esistono distro Linux dedicate alle indagini su criptovalute.

Concetti di base

- Le transazioni su blockchain pubbliche (Bitcoin, Ethereum, ecc.) sono **trasparenti e consultabili da chiunque**, ma sono collegate a indirizzi alfanumerici (wallet) e non direttamente a un'identità: l'OSINT su crypto consiste nel tracciare i movimenti tra wallet e, dove possibile, collegarli a un exchange, un servizio o un'identità nota.
- Il **tracciamento cross-chain** segue i fondi anche quando vengono spostati da una blockchain a un'altra (es. da Bitcoin a Ethereum tramite un bridge o un exchange).
- Alcuni soggetti cercano di aumentare l'anonimato delle proprie transazioni tramite i cosiddetti **mixer (o tumbler)**: servizi che raccolgono fondi da più utenti, li mescolano tra loro e li restituiscono, rendendo più complesso ricostruire il collegamento diretto tra mittente e destinatario originali. Questo rende il tracciamento più difficile, ma non impossibile: piattaforme di blockchain analytics avanzate (es. Chainalysis, Crystal Intelligence) sono in grado, in molti casi, di identificare pattern sospetti anche attraverso un mixer.

Procedura pratica

1. Individuare l'indirizzo del wallet da esaminare.
2. Usare un blockchain explorer specifico per la valuta (es. Etherscan per Ethereum) per vedere lo storico delle transazioni.
3. Per tracciamenti più complessi o cross-chain, usare piattaforme OSINT dedicate come Arkham Intelligence.
4. Per un'analisi automatizzata più ampia, è possibile usare SpiderFoot, chiedendo eventualmente assistenza passo passo a un'AI per impostare la ricerca.

Strumenti

Arkham Intelligence	Sito web consultabile	Piattaforma OSINT per analizzare e tracciare transazioni crypto, con collegamento a entità note (exchange, aziende, individui).
Zerion	Sito web consultabile / app	Wallet e dashboard che permette di monitorare un portafoglio crypto attraverso decine di blockchain diverse, utile per tracciamento cross-chain.
Etherscan.io	Sito web consultabile	Blockchain explorer per Ethereum: consente di consultare transazioni, wallet e smart contract.
Blockchair	Sito web consultabile	Blockchain explorer multi-valuta.
Blockpath	Sito web consultabile	Strumento di analisi e visualizzazione di transazioni blockchain.
Bitcoin Who's Who	Sito web consultabile	Database di indirizzi Bitcoin con relative segnalazioni/reputazione.
Crystal Intelligence	Sito web consultabile	Piattaforma di analisi wallet e compliance/AML per blockchain.
Chainalysis	Sito web consultabile	Piattaforma professionale di blockchain analytics, usata anche da autorità ed exchange per compliance e indagini.
SpiderFoot	Tool utilizzabile su Kali Linux	Piattaforma di raccolta OSINT automatizzata, utilizzabile anche per ricerche legate a indirizzi crypto.

Concetti di base

- Il dark web è la porzione di internet accessibile solo tramite software specifici come **Tor**, che instrada il traffico attraverso più nodi criptati per garantire anonimato a chi naviga e a chi ospita i siti (domini .onion).
- Molti strumenti di analisi avanzata del dark web sono a pagamento, ma buona parte delle informazioni utili si può comunque ottenere sfruttando dati già pubblici nel clear web (il web "normale" indicizzato dai motori di ricerca).
- Esistono anche **hidden wiki secondarie** (elenchi di link .onion alternativi), utili quando quella principale non restituisce risultati validi.

Procedura pratica

Verifica se un IP è associato alla rete Tor:

1. Usare Tor Browser.
2. Cercare l'IP su Tor Relay Search.
3. Se l'IP è italiano, applicare il filtro country:it (lo stesso metodo vale per qualsiasi altro paese).
4. Verificare se compare tra i relay Tor di quel paese.

Ricerca e discovery di siti .onion:

1. Usare Ahmia o motori di ricerca dark web equivalenti per individuare servizi .onion.
2. Consultare liste/mappature manuali di link (Onion Tree o simili) come integrazione.

Analisi tecnica di un servizio .onion:

1. Usare OnionScan per individuare eventuali leak IP, configurazioni errate o collegamenti al clearnet lasciati per errore dal gestore del sito.

Raccolta prove da un sito .onion:

1. Creare un mirror controllato della pagina con wget o HTTrack, per fini di archiviazione e acquisizione probatoria.
2. Per certificarne l'integrità (vedi anche sezione 18 — Forensics) calcolare l'hash del contenuto raccolto.
3. Analizzare eventuali metadati dei file pubblicati con ExifTool.

Nota su forum e marketplace: chi opera ricerche su forum/marketplace del dark web utilizza generalmente identità isolate ("sock puppet") create appositamente per l'attività di osservazione, separate dalla propria identità reale, e si limita a monitorare pattern comportamentali pubblici (nickname, orari di attività) senza interagire attivamente.

Strumenti — Ricerca e discovery

Ahmia	Sito web consultabile / motore di ricerca .onion	Motore di ricerca per domini .onion, utilizzabile direttamente da Tor Browser; è l'equivalente di Google per il dark web.
DarkSearch	Sito web consultabile	Motore di ricerca OSINT per il dark web.
Onion Tree / liste di onion link	Sito web consultabile	Mappatura manuale di link .onion.

Strumenti — Analisi e correlazione

Maltego / Maltego CE	Software desktop (Windows/Mac/Linux)	Tra i migliori strumenti per investigazioni OSINT, usato anche in casi reali di analisi di marketplace del dark web; correla identità .onion e clearnet.
OnionScan	Tool utilizzabile su Kali Linux	Individua leak IP, configurazioni errate e collegamenti al clearnet nei servizi .onion.
SpiderFoot	Tool utilizzabile su Kali Linux	Raccolta OSINT automatizzata (vedi anche sezione 13).
Amass (modalità passiva)	Tool utilizzabile su Kali Linux	Identificazione di infrastrutture correlate a un dominio/organizzazione.
ExoneraTor	Sito web consultabile	Verifica se un IP era un nodo Tor in una data specifica (vedi anche sezione 1).
Tor Relay Search	Sito web consultabile	Ricerca tra i relay Tor attivi, filtrabile per paese (vedi anche sezione 1).

Strumenti — Raccolta prove

wget	Tool utilizzabile su Kali Linux	Crea mirror controllati di pagine/siti per archiviazione.
HTTrack	Tool utilizzabile su Kali Linux	Alternativa a wget per il mirroring completo di un sito.
sha256sum	Tool utilizzabile su Kali Linux	Calcola l'hash di file o pagine raccolte, per certificarne l'integrità.
ExifTool	Tool utilizzabile su Kali Linux	Analisi dei metadati dei file pubblicati (vedi anche sezione 7).
Hunchly	Software desktop (a pagamento)	Strumento professionale per la raccolta e catalogazione automatica di prove durante una ricerca web.

21 TRACKING AEREI

Concetti di base

- I siti di flight tracking raccolgono dati pubblici trasmessi dai transponder degli aerei (protocollo ADS-B) per mostrare in tempo reale posizione, altitudine, velocità e rotta dei voli.

Strumenti

Flightradar24	Sito web consultabile	Tracciamento in tempo reale di voli commerciali e privati a livello globale.
FlightAware	Sito web consultabile	Tracciamento voli e dati storici di rotte.
ADSBExchange	Sito web consultabile	Tracciamento voli basato su dati ADS-B non filtrati, include anche voli che altri servizi potrebbero oscurare su richiesta.

22 MARCHI E PROPRIETÀ INTELLETTUALE

Concetti di base

- Un **marchio registrato** garantisce protezione legale esclusiva su un nome, logo o segno distintivo in un determinato territorio; la ricerca su questi database serve per verificare se un marchio è già registrato, da chi e per quali categorie merceologiche.

Strumenti

EUIPO	Sito web consultabile	Ufficio dell'Unione Europea per la Proprietà Intellettuale: registro marchi e disegni a livello UE.
TMview	Sito web consultabile	Motore di ricerca marchi che aggrega database di più uffici nazionali e internazionali.

23 VERIFICA DI FOTO/VIDEO FALSI E BANCONOTE CONTRAFFATTE

Concetti di base

- L'analisi forense di un'immagine o video (livelli di compressione, incoerenze nei metadati, artefatti di editing) può aiutare a stabilire se un contenuto è stato manipolato o generato artificialmente.
- Conoscere anche gli strumenti usati per **generare** contenuti falsi (deepfake, immagini sintetiche) è utile per capire cosa cercare durante una verifica: sapere come viene prodotto un artefatto aiuta a riconoscerlo.

Strumenti — Verifica

FotoForensics	Sito web consultabile	Analisi forense di foto (e in parte video) per individuare tracce di manipolazione (vedi anche sezione 7).
---------------	-----------------------	--

Strumenti — Generazione (per riferimento, utili a capire cosa riconoscere)

flux-ai.io	Sito web consultabile	Piattaforma di generazione di immagini/video tramite intelligenza artificiale; citata come riferimento per comprendere gli artefatti tipici dei contenuti generati sinteticamente.
------------	-----------------------	--

Banconote contraffatte

CRIMNET – DCPC	Banca dati istituzionale	Sistema di riferimento della Direzione Centrale della Polizia Criminale per la ricerca su banconote contraffatte.
----------------	--------------------------	---

Concetti di base

- L'**hash** è un'impronta digitale univoca di un file: basta una modifica minima al contenuto per produrre un hash completamente diverso. Confrontare l'hash di due file permette di verificarne l'identità assoluta.
- Il **timestamping** (marcatura temporale) permette di dimostrare che un determinato file esisteva, in una certa forma, a una certa data — utile per dimostrare la paternità o l'esistenza di un documento in un momento specifico.

Procedura pratica: dimostrare che un file esisteva a una certa data

Metodo 1 — Hash + servizio con timestamp:

1. Calcolare l'hash della cartella o del file (se sono più file, comprimerli in una cartella ZIP).
2. Caricare l'hash (o il file) su un servizio con marcatura temporale certa, come Google Drive: la data e ora di caricamento fungono da riferimento temporale.

Metodo 2 — OpenTimestamps (consigliato, più solido):

1. Caricare il file (es. prova.txt) sul sito o tramite lo strumento OpenTimestamps.
2. Il sistema genera l'hash del file e un file .ots, che rappresenta la prova crittografica dell'esistenza e dell'originalità del documento in quel momento.
3. L'hash viene registrato sulla blockchain Bitcoin. Dopo circa un giorno, l'operazione è consolidata e non più modificabile.
4. Per la verifica successiva, si caricano insieme il file originale e il file .ots: il sistema conferma che il documento è identico a quello depositato e che esisteva in quella data precisa.

Perché OpenTimestamps è affidabile:

- È open source e indipendente: non richiede fiducia in un ente centrale.
- Si appoggia alla blockchain Bitcoin, pubblica, immutabile e trasparente.
- È leggero e universale: funziona con qualsiasi tipo di file, senza limiti di formato.
- La blockchain non può essere alterata né cancellata una volta registrato l'hash; anche una modifica minima al file produce un'impronta completamente diversa, garantendo un'integrità totale della prova.

Strumenti

OpenTimestamps	Sito web consultabile / servizio	Marcatura temporale di un file basata su blockchain Bitcoin, con prova crittografica verificabile in qualsiasi momento.
QuickHash GUI	Software desktop (Windows/Linux)	Calcola l'hash di singoli file o intere cartelle; gratuito.
HashMyFiles	Software desktop (Windows)	Alternativa a QuickHash per il calcolo di hash di file.
sha256sum	Tool utilizzabile su Kali Linux	Calcolo hash da riga di comando (vedi anche sezione 14).

FIT — Freezing Internet Tool

Cos'è: FIT (il cui acronimo, nonostante il nome comunemente usato "Forensic Imaging Tool", sta per *Freezing Internet Tool*) è un'applicazione open source in Python pensata per l'acquisizione forense di contenuti online — pagine web, email, contenuti social e altro — direttamente da internet. Nasce come progetto di tesi per un Master in Cybersecurity, Digital Forensics e Data Protection, ed è oggi mantenuto come suite open source su GitHub.

Come funziona, a livello generale: a differenza di un semplice screenshot, FIT acquisisce un contenuto web "congelandolo" con più livelli di garanzia contemporaneamente: salva il codice sorgente della pagina, registra la sessione di acquisizione (video e, se necessario, audio dello schermo), effettua una cattura del traffico di rete generato durante l'acquisizione (tramite la libreria Scapy) e calcola l'hash del materiale raccolto per certificarne l'integrità — lo stesso principio già visto nella sezione dedicata a hashing e timestamping.

Tipologie di acquisizione supportate: pagine web pubbliche, contenuti email, contenuti social media, oltre a funzionalità di verifica per timestamp su PDF e per PEC, a seconda del modulo utilizzato.

Funzionalità principali:

- Acquisizione forense di pagine web con salvataggio di codice sorgente, screenshot e registrazione video della sessione.
- Cattura del traffico di rete generato durante l'acquisizione, per documentare tecnicamente cosa è avvenuto tra il dispositivo e il sito acquisito.
- Calcolo automatico dell'hash del materiale raccolto, per garantirne l'integrità nel tempo.
- Gestione dei "casi": organizzazione delle acquisizioni per procedimento/fascicolo, con persistenza dei dati tramite database locale.

Casi d'uso: è pensato per chi ha necessità di documentare in modo tecnicamente solido il contenuto di una pagina web o di una comunicazione digitale in un dato momento — ad esempio per un procedimento legale, una perizia, o più in generale qualunque situazione in cui un contenuto online potrebbe cambiare o essere rimosso prima che se ne possa dare conto altrimenti.

Vantaggi: è gratuito, open source, e copre in un unico strumento più aspetti dell'acquisizione forense (codice sorgente, video, rete, hash) che altrimenti richiederebbero più strumenti separati.

Limitazioni: il progetto è attualmente in fase di transizione architetturale (dalla versione monolitica 2.X, non più aggiornata, a una nuova suite modulare in sviluppo verso la versione 3.0), quindi prima di un uso operativo è consigliabile verificare lo stato di sviluppo e la documentazione più recente sul repository ufficiale. Come ogni strumento di acquisizione, inoltre, il valore probatorio finale dipende anche dal corretto utilizzo e dal contesto legale in cui viene impiegato, non dal solo strumento.

FIT (Freezing Internet Tool)	Tool utilizzabile su Kali Linux / altre distro Linux (open source)	Acquisizione forense di pagine web, email e contenuti social con salvataggio di codice sorgente, video, cattura di rete e hash di integrità.
---	--	--

25 SEGNALAZIONE SITI TRUFFA

Concetti di base

- Diversi enti pubblici e privati offrono strumenti gratuiti per verificare se un sito è segnalato come pericoloso o per segnalarne uno nuovo.

Procedura pratica

1. Verificare il sito su Google Safe Browsing e/o Microsoft SmartScreen per controllare se è già segnalato.
2. Controllare il WHOIS del dominio per individuare l'email di abuse del provider di hosting e segnalare direttamente lì.

Siti per segnalare siti truffa

Google Safe Browsing	Sito web consultabile	Verifica se un sito è segnalato come pericoloso da Google.
Microsoft SmartScreen (Edge)	Sito web consultabile	Verifica/segnalazione di siti pericolosi tramite il sistema di protezione Microsoft.
whois.domaintools.com	Sito web consultabile	WHOIS del dominio, utile per trovare l'email di abuse a cui segnalare (vedi anche sezione 1).
Polizia Postale (commissariatodips.it)	Sito web istituzionale	Portale ufficiale per segnalare truffe online alla Polizia Postale italiana.
AGCM — Segnalazioni online (agcm.it/servizi/segnala-on-line)	Sito web istituzionale	Portale dell'Autorità Garante della Concorrenza e del Mercato per segnalare possibili pratiche commerciali scorrette o siti sospetti.

26 FRAMEWORK OSINT GENERICI (MULTI-FUNZIONE)

Concetti di base

- I framework OSINT generici sono strumenti che eseguono ricerche OSINT su più tipi di dato contemporaneamente (email, username, IP, social, breach, ecc.), offrendo più funzioni in un unico tool invece di doverne usare uno diverso per ogni tipo di ricerca.
- **OSINT Framework** (osintframework.com) è una mappa interattiva online che, per ogni tipo di informazione da cercare, indica gli strumenti più adatti.

Strumenti

OSINT Framework	Sito web consultabile	Mappa interattiva di strumenti OSINT organizzata per categoria di dato da ricercare.
Mr. Holmes	Tool utilizzabile su Kali Linux	Framework OSINT completo per la raccolta di informazioni da più fonti.
Recon-ng	Tool utilizzabile su Kali Linux	Framework modulare di ricognizione OSINT, con moduli per email, domini, social e altro.
ClatScope	Tool utilizzabile su Kali Linux	Tool OSINT testuale che analizza IP (geolocalizzazione, DNSBL), numeri di telefono, email (validità e breach su HaveIBeenPwned), header email, username multi-piattaforma e certificati SSL.
IntelOSINT	Tool utilizzabile su Kali Linux	Tool per ricerche OSINT generali, creato da CScorza — un autore/analista OSINT italiano che consiglio di seguire per chi è interessato a questo settore: ha pubblicato diversi altri strumenti e manuali di alto livello sull'argomento.
Ghost Tracker	Tool utilizzabile su Kali Linux	Tool OSINT che analizza IP (geolocalizzazione, reputazione), numeri di telefono (operatore, fuso orario), username, email/domini e indirizzi crypto.
Maltego / Maltego CE	Software desktop (Windows/Mac/Linux)	Tra i migliori strumenti per investigazioni OSINT: correla graficamente entità diverse (persone, domini, email, IP, aziende) mostrando le relazioni tra loro (vedi anche sezione 14).
Blackbird	Tool utilizzabile su Kali Linux	Ricerca OSINT su username ed email (vedi anche sezioni 4 e 5).
Recosint	Sito web consultabile	Raccolta di tool OSINT basati su intelligenza artificiale (recosint.com/tools).
OSINT Industries	Sito web consultabile (a pagamento)	Piattaforma di reverse lookup che, a partire da email, numero di telefono, username o wallet crypto, incrocia centinaia di fonti pubbliche restituendo un profilo con gli account collegati, eventuali breach ed elementi di attività online. Punto di forza: copertura molto ampia e risultati in tempo reale su un numero elevato di piattaforme (social, servizi, app di lifestyle). Limite: nessun piano gratuito permanente, e come ogni strumento aggregatore la qualità del risultato dipende dai dati effettivamente esposti pubblicamente dal soggetto cercato.

27 TOOLKIT KALI LINUX — RIEPILOGO PER CATEGORIA

Questa sezione raccoglie in un unico elenco tutti i tool da terminale già presentati nel manuale, organizzati per categoria, come riferimento rapido per chi lavora principalmente da Kali Linux (o altra distro Linux equivalente).

Strumenti generali (multi-funzione)

Mr. Holmes · Recon-ng · ClatScope · IntelOSINT · Ghost Tracker · SpiderFoot · Maltego

Email

Holehe · GHunt · Recon-ng

Numeri di telefono

PhoneInfoga · Ignorant

Username

Sherlock · Blackbird · Tookie OSINT · Ignorant · user-scanner

Domini, sottodomini, certificati

theHarvester · Knock · cert-cli · Amass

Metadati

ExifTool

Instagram

Instaloader · Osintgram

Dark Web

OnionScan · Amass

Anonimato

TorGhost · AnonSurf · ProxyChains · Nipe

Raccolta prove e archiviazione

Project FIT · Web Forensic Instantsha256sumwget · HTTrack ·

Note e gestione file

Gedit · Glogg

Concetti di base

- Durante una ricerca OSINT si accumulano rapidamente molti dati eterogenei (testo, log, file di grandi dimensioni): avere gli strumenti giusti per annotare, cercare ed elaborare questi dati velocizza il lavoro e riduce gli errori.

Strumenti — Editor di testo e appunti

Notepad++	Software desktop (Windows)	Editor di testo leggero, utile per annotare dati raccolti durante una ricerca.
Gedit	Tool utilizzabile su Kali Linux	Editor di testo semplice per appunti rapidi.

Strumenti — Gestione file di grandi dimensioni

Glogg	Tool utilizzabile su Kali Linux (disponibile anche per Windows)	Permette di caricare e analizzare file di testo o CSV molto grandi (log, dati tabulati) in modo efficiente.
Agent Ransack	Software desktop (Windows)	Cerca rapidamente contenuti specifici all'interno di file e cartelle.

Strumenti — Fogli di calcolo e analisi dati

OpenCalc (Apache OpenOffice Calc)	Software desktop (Windows/Mac/Linux)	Foglio di calcolo gratuito, alternativa a Excel.
--	--------------------------------------	--

Strumenti — Visualizzazione grafi e correlazioni

Gephi	Software desktop (Windows/Mac/Linux)	Software per la visualizzazione di grafi e reti di relazioni; alternativa gratuita a Maltego per la parte di visualizzazione.
Cytoscape	Software desktop (Windows/Mac/Linux)	Come Gephi: visualizzazione di reti e correlazioni tra dati, alternativa a Maltego.

Metodo di lavoro consigliato per il report finale

1. Aprire una scheda di lavoro (es. su Glogg o Notepad++) man mano che si procede con la ricerca.
2. Annotare tutto in modo ordinato durante la raccolta, non solo alla fine.
3. Una volta completata la raccolta, riorganizzare gli appunti con l'aiuto di un'AI per ottenere un report pulito e strutturato.

Concetti di base

- Il **Google Dorking** consiste nell'usare operatori di ricerca avanzata di Google per trovare informazioni specifiche che una ricerca normale non mostrerebbe facilmente: pagine nascoste, file specifici, contenuti su un dominio preciso, ecc.
- Sfrutta solo funzionalità di ricerca già messe a disposizione da Google, senza violare o aggirare alcuna protezione. Il motore di ricerca indicizza automaticamente qualsiasi contenuto pubblicamente raggiungibile sul web; il dorking si limita a interrogare in modo più mirato quell'indice già esistente, facendo emergere contenuti che una ricerca generica lascerebbe sepolti tra migliaia di risultati.
- Memorizzare tutti gli operatori e le combinazioni possibili è poco pratico: è più smart chiedere direttamente a un'AI (Claude, ChatGPT, ecc.) di costruire la query di dorking più adatta al momento, descrivendo semplicemente cosa si sta cercando.

Cosa si può scoprire, in pratica

Con query mirate è possibile far emergere contenuti che i proprietari dei siti spesso non si rendono conto di aver reso pubblici e indicizzabili. Alcuni esempi tipici:

- **Curriculum pubblicati online** contenenti dati personali (nome, contatti, esperienze lavorative), caricati come PDF o DOC su siti aziendali o personali senza restrizioni di accesso.
- **Documenti indicizzati per errore**: file interni (verbali, bozze, fogli di calcolo) che finiscono online per una configurazione errata del sito, senza che chi li ha caricati se ne accorga.
- **Directory esposte**: cartelle di file accessibili direttamente da browser (tipicamente riconoscibili dal titolo "Index of /...") a causa di una configurazione del server che non blocca la visualizzazione del contenuto della cartella.
- **File PDF, Excel o Word pubblicamente accessibili**: documenti che, pur non essendo linkati da nessuna pagina visibile del sito, restano comunque raggiungibili e indicizzati se il server non ne impedisce esplicitamente l'accesso diretto.
- **Aree di un sito non pensate per essere facilmente trovabili**: pagine di test, pannelli amministrativi, sezioni "nascoste" che non compaiono nel menu di navigazione ma che, non essendo protette da autenticazione, vengono comunque indicizzate.

È importante essere chiari su un punto: il Google Dorking non permette di "entrare" in un sito, aggirare una password o accedere a qualcosa di protetto. Fa emergere esclusivamente contenuti già pubblici e già indicizzati dal motore di ricerca — la scoperta sta nel sapere *come cercarli*, non nel violare una barriera di sicurezza.

Operatori principali

site:	Limita la ricerca a un dominio specifico	site:esempio.it contratto
filetype:	Cerca solo un tipo di file	filetype:pdf site:esempio.it
intitle:	Cerca parole nel titolo della pagina	intitle:"index of"
inurl:	Cerca parole nell'URL della pagina	inurl:login site:esempio.it
intext:	Cerca parole nel testo del corpo della pagina	intext:"password" filetype:log
"frase esatta"	Cerca una frase esatta	"riservato ad uso interno"
-parola	Esclude un termine dai risultati	sito ufficiale -wikipedia
OR	Cerca l'uno o l'altro termine	site:esempio.it (login OR accesso)

Combinazioni pratiche utili

- `site:esempio.it filetype:pdf` → trova tutti i PDF pubblicati su un dominio.
- `intitle:"index of" site:esempio.it` → cerca directory di file esposte per errore.
- `site:t.me nomeutente` → trova gruppi/canali Telegram collegati a uno username (vedi anche sezione 5).
- `site:linkedin.com/in "nome azienda"` → trova profili LinkedIn collegati a un'azienda specifica.
- `site:esempio.it filetype:csv OR filetype:xlsx` → cerca fogli di calcolo pubblicati sul dominio.

Dorking oltre Google

Le stesse tecniche di ricerca avanzata non sono esclusive di Google: la maggior parte dei motori di ricerca supporta operatori analoghi (anche se con sintassi e copertura leggermente diverse), tra cui:

- **Yandex:** motore di ricerca russo, spesso utile in ambito OSINT anche per la ricerca inversa di immagini (vedi sezione Immagini, Metadati e GEOSINT); supporta operatori simili a Google.
- **Bing:** motore di Microsoft, indicizza in parte contenuti diversi da Google e supporta operatori equivalenti (es. `site:`, `filetype:`, `intitle:`).
- **Brave Search:** motore di ricerca indipendente con proprio indice, utile come fonte alternativa quando Google non restituisce risultati soddisfacenti.
- **DuckDuckGo:** motore orientato alla privacy, con proprio indice parzialmente diverso da quello di Google e Bing.

Ogni motore indicizza dati differenti e può restituire risultati diversi anche con la stessa query: per una ricerca approfondita, può essere utile ripetere le stesse query di dorking su più motori, non fermandosi al primo risultato ottenuto.

Strumenti

DorkGPT	Sito web consultabile	Aiuta a costruire query di Google Dorking corrette e mirate tramite intelligenza artificiale, senza dover memorizzare tutti gli operatori.
----------------	-----------------------	--

Concetti di base

- I siti web spesso cambiano nel tempo: vecchie pagine, script JavaScript o chiamate API possono restare attivi sul server anche se non più collegati o visibili dal sito attuale.
- Wayback Machine (già introdotto in sezione 2) non serve solo per vedere com'era una pagina in passato: consultando le versioni storiche del codice sorgente e dei file JavaScript di un sito, è possibile scoprire URL di API o endpoint che oggi non sono più linkati da nessuna parte nel sito attuale, ma che a volte restano ancora raggiungibili e funzionanti.

Procedura pratica

1. Cercare il dominio su Wayback Machine e selezionare snapshot di diverse epoche.
2. Analizzare i file JavaScript caricati dalle versioni storiche del sito (spesso contengono URL di chiamate API incorporati nel codice).
3. Verificare manualmente se gli endpoint trovati sono ancora raggiungibili sul dominio attuale.
4. Se il volume di snapshot da controllare è alto, uno strumento come Waybackurls (da riga di comando) può automatizzare l'estrazione degli URL storici di un dominio.

Strumenti

Wayback Machine (Archive.org)	Sito web consultabile	Archivio storico di pagine e file di un sito (vedi anche sezione 2).
Waybackurls	Tool utilizzabile su Kali Linux	Estrae in automatico tutti gli URL storicamente archiviati per un dominio da Wayback Machine.

31 RICERCA DI DISPOSITIVI CONNESSI A INTERNET

Concetti di base

- **Shodan** e **Censys** sono motori di ricerca specializzati non su pagine web (come Google), ma su **dispositivi connessi a internet**: server, webcam, router, sistemi industriali, database esposti, ecc.
- Sono strumenti standard nel campo della sicurezza informatica e della ricognizione di infrastrutture: permettono di scoprire quali servizi/porte sono esposti pubblicamente su un IP o dominio, con che versione di software, e se sono note vulnerabilità associate.
- Sono strumenti legittimi e ampiamente usati anche da chi si occupa di difesa (per verificare cosa della propria infrastruttura è visibile dall'esterno), oltre che da ricercatori di sicurezza e giornalisti investigativi.

Procedura pratica

1. Cercare un IP o un dominio su Shodan/Censys per vedere quali porte e servizi risultano esposti pubblicamente.
2. Verificare versione del software in esecuzione e configurazioni visibili.
3. Incrociare con VirusTotal o AbuseIPDB (sezione 1) per un quadro più completo sulla reputazione dell'host.

Strumenti

Shodan	Sito web consultabile (funzioni avanzate a pagamento)	Motore di ricerca di dispositivi connessi a internet: server, webcam, sistemi IoT, database esposti.
Censys	Sito web consultabile (funzioni avanzate a pagamento)	Motore di ricerca analogo a Shodan, per la scoperta di dispositivi e infrastrutture esposte in rete.

Gli strumenti e le tecniche presentati in questo manuale sono destinati esclusivamente alla raccolta, analisi e verifica di informazioni pubblicamente disponibili, nell'ambito di attività lecite e autorizzate. L'utilizzo di tali strumenti deve rispettare la normativa vigente, la privacy delle persone coinvolte e i principi di responsabilità professionale. Non effettuare accessi non autorizzati, tentativi di intrusione, scansioni invasive o attività di raccolta dati al di fuori degli scopi consentiti.

I casi che seguono sono esempi didattici brevi, con dati interamente fittizi (nomi, email, domini e riferimenti inventati a scopo illustrativo), pensati per mostrare in pratica come si applica il metodo descritto nel resto del manuale — in particolare il pivoting (vedi sezione “Esempi Pratici di Correlazione”) e il workflow generico (vedi “Processo Operativo OSINT”). Nessuno di questi esempi fa riferimento a persone, aziende o eventi reali.

Caso 1 — Da un’email a una possibile identità Punto di partenza: un indirizzo email ricevuto in un contesto sospetto (`m.rossi.contatti@example.com`). Verifica su Holehe: l’email risulta registrata su un servizio di food delivery e su una piattaforma social. Il nome utente associato al profilo social, incrociato con una ricerca inversa, porta a un profilo pubblico con nome e città coerenti con altri elementi già noti. Metodo: email → Holehe → username → profilo social → nome plausibile (sezioni 3, 4, 5).

Caso 2 — Da una foto alla geolocalizzazione Punto di partenza: una foto ricevuta senza contesto, che mostra uno scorcio urbano con un’insegna parzialmente leggibile. I metadati EXIF non contengono coordinate (probabilmente rimossi dal passaggio su un’app di messaggistica). Si isola il dettaglio dell’insegna con GIMP, si esegue una ricerca inversa su Yandex Images, e si confronta il risultato con Google Street View fino a individuare l’incrocio esatto. Metodo: foto → EXIF/ricerca inversa → confronto mappe (sezione 8).

Caso 3 — Da un dominio alla ricostruzione di un’infrastruttura Punto di partenza: un dominio aziendale sospetto. Con `crt.sh` emergono diversi sottodomini non collegati dal sito principale (`staging.`, `admin.`). WhatWeb rivela il CMS utilizzato; il WHOIS mostra la data di registrazione recente. L’insieme suggerisce un sito allestito rapidamente, con un pannello di amministrazione esposto per errore. Metodo: dominio → certificati SSL/sottodomini → WHOIS → CMS (sezione 1).

Caso 4 — Da un nickname all’identificazione di un profilo Punto di partenza: uno username incontrato in un forum. Una ricerca con Sherlock lo trova attivo su altre tre piattaforme, tra cui una con biografia pubblica che cita una città e una professione. Verifica incrociata: lo stesso username, con una variazione minima, è registrato anche su un servizio di portfolio professionale, dove compare un nome completo. Metodo: username → ricerca multi-piattaforma → profilo con dati aggiuntivi (sezione 4).

Caso 5 — Un’email di tipo BEC (phishing aziendale) Punto di partenza: un’email apparentemente proveniente da un fornitore abituale, che comunica un cambio di IBAN per i pagamenti futuri. Controllando il dominio del mittente carattere per carattere si nota una lettera diversa rispetto al dominio originale (typosquatting). Il controllo degli header conferma un server di invio non coerente con l’infrastruttura nota del fornitore reale. Esito: la richiesta viene bloccata e verificata telefonicamente con un contatto già noto. Metodo: email sospetta → analisi dominio/header → verifica fuori banda (sezione 3).

Caso 6 — Da un nome reale a informazioni collegate Punto di partenza: nome e cognome di una persona, senza altri dati. Una ricerca incrociata su registri pubblici e social network porta a un profilo LinkedIn con città e professione dichiarate; da lì si individua un indirizzo email professionale nel formato aziendale standard (`nome.cognome@azienda.example`), poi verificato con Holehe su altri servizi. Lo stesso nome, cercato tra virgolette su Google, restituisce anche un profilo su un forum di settore con uno username ricorrente. Metodo: nome reale → social/registri pubblici → email plausibile → username collegato (sezioni 3, 4, 5).

Caso 7 — Da un numero di telefono al proprietario Punto di partenza: un numero di telefono ricevuto in un contesto sospetto. Un servizio di HLR lookup conferma che si tratta di una linea mobile reale, non VoIP. Il numero, salvato in rubrica, mostra un nome e una foto profilo pubblici su un’app di messaggistica. Una ricerca del numero tra virgolette su Google restituisce un annuncio online con lo stesso contatto, che riporta anche un nome completo. Metodo: numero di telefono → verifica linea → nome/foto pubblici → riscontro incrociato (sezione 4).

Caso 8 — Tracciamento base di un wallet crypto Punto di partenza: un indirizzo di wallet Bitcoin ricevuto come destinatario di un pagamento sospetto. Su un blockchain explorer si osserva lo storico delle transazioni: il wallet ha ricevuto fondi da più fonti diverse in un breve lasso di tempo e li ha rapidamente inoltrati verso un altro indirizzo, un pattern compatibile con un tentativo di disperdere le tracce. Arkham Intelligence non trova un collegamento diretto a un’entità nota. Metodo: wallet → blockchain explorer → pattern di movimento (sezione 12).